

CEN/CLC/JTC 13

Date: 2026-05-12

prEN 40000-1-3

Secretariat: DIN

WI Number: JT013090

Cybersecurity requirements for products with digital elements - Part 1-3: Vulnerability Handling

ICS: 35.030

CCMC will prepare and attach the official title page.

Contents.....	Page
European foreword.....	Error! Bookmark not defined.
Introduction	Error! Bookmark not defined.
Scope.....	Error! Bookmark not defined.
Normative references.....	Error! Bookmark not defined.
Terms and definitions.....	Error! Bookmark not defined.
General	Error! Bookmark not defined.
Structure of this document.....	Error! Bookmark not defined.
Relationships with other international standards	Error! Bookmark not defined.
Vulnerability handling.....	Error! Bookmark not defined.
General	Error! Bookmark not defined.
[APP] Applicability (WE DECIDED TO REMOVE THIS SECTION IN WG9 MEETING IN STOCKHOLM).....	Error! Bookmark not defined.
[PRE] Preparation.....	Error! Bookmark not defined.
[RCP] Receipt.....	Error! Bookmark not defined.
[VRF] Verification	Error! Bookmark not defined.
[RMD] Remediation.....	Error! Bookmark not defined.
[RLS] Release.....	Error! Bookmark not defined.
[PRA] Post-release.....	Error! Bookmark not defined.
(informative) (NEW ANNEX: HASR2-002 / HAS-3089) - RISKS COLLECTIONS AND MAPPING	Error! Bookmark not defined.
(informative) Recommendations	Error! Bookmark not defined.
Bibliography.....	Error! Bookmark not defined.

European foreword

This document (prEN 40000-1-3:2026) has been prepared by Technical Committee CEN/CLC JTC 13 “Cybersecurity and Data Protection”, the secretariat of which is held by DIN.

This document is currently submitted to the CEN Enquiry.

This document has been prepared under a standardization request addressed to CEN-CENELEC by the European Commission. The Standing Committee of the EFTA States subsequently approves these requests for its Member States.

For the relationship with EU Legislation, see informative Annex ZA, which is an integral part of this document.

Introduction

Vulnerabilities are likely to emerge over time during the life cycle of a product with digital elements (hereinafter referred to as "product"), including its software and hardware components, despite adherence to cybersecurity principles defined in [Error! Reference source not found.](#)

It is important to prepare for those events by developing an effective strategy for the management of vulnerabilities during the product life cycle, including regular monitoring, testing, risk assessment, prioritization, remediation, and verification, as well as communication, which are all essential activities to discover and fix new vulnerabilities and maintain cybersecurity coverage.

This vulnerability handling document refines the activities that are part of international standards such as [Error! Reference source not found.](#), [Error! Reference source not found.](#), and [Error! Reference source not found.](#). It elevates, where appropriate, recommendations to mandatory requirements to ensure conformity with the Cyber Resilience Act (CRA) obligations. It integrates essential elements such as Software Bill of Materials (SBOM), regular testing and review activities, secure update mechanisms, and explicit requirements to support effective Coordinated Vulnerability Disclosure (CVD) and vulnerability-handling processes.

The rigor with which vulnerability handling activities are expected to be executed are expected to adhere to a risk-based approach, determined by the potential societal impact of a product's security failure. For example, the regular test and other monitoring activities are expected to be executed more frequently for products with higher criticality, and having a more detailed SBOM can improve the detection of vulnerabilities in components used by the product. The horizontal standards for the Cyber Resilience Act cannot be too prescriptive and thus require appropriate product risk-based criteria to be documented in the risk assessment and the cybersecurity plan for the product.

Identifying a product that can cause high-risk impact, which can be found across all categories covered by the Cyber Resilience Act, is integral to the regulatory risk assessment that needs to be conducted by the manufacturer. To support a risk-based approach, this document defines requirement enhancements.

Figure 1 illustrates an example of the vulnerability life cycle model, where the period between vulnerability discovery and the application of security updates prolongs the window of opportunity for threat actors to exploit the vulnerability and to conduct a cybersecurity attack.

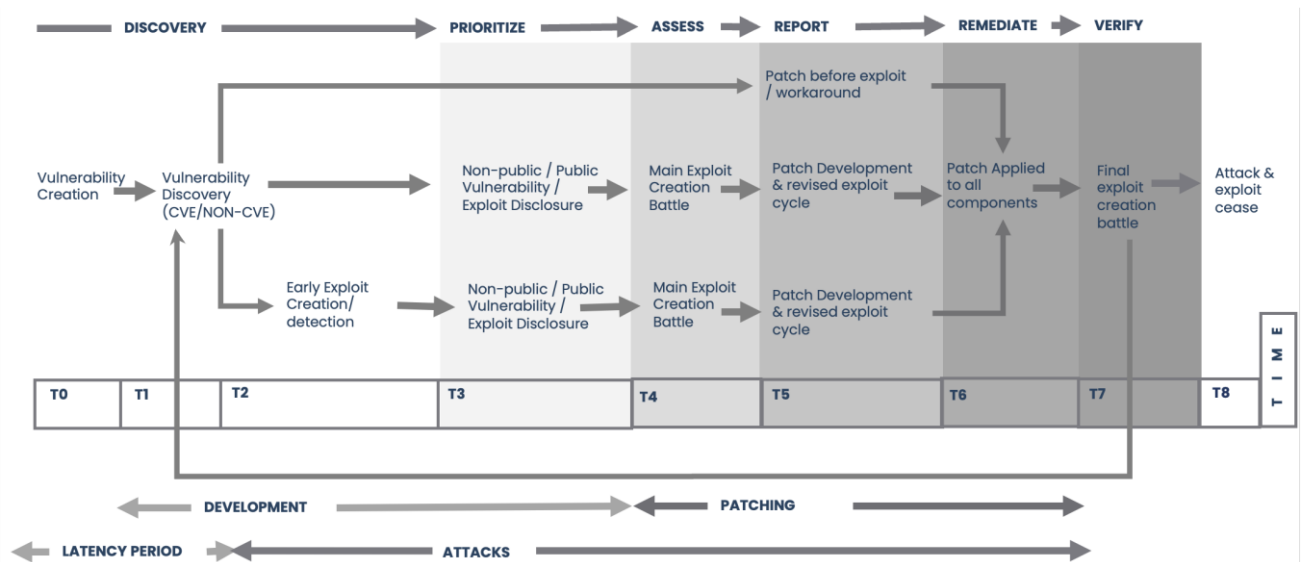


Figure 1 — Vulnerability life cycle

The vulnerability handling activities defined in this document are organized into the following distinct phases:

- **Preparation:** Establishing policies, processes, and capabilities for vulnerability intake and disclosure.
- **Receipt:** Receiving and monitoring vulnerability reports from internal and external sources.
- **Verification:** Assessing the validity, applicability, and severity of reported vulnerabilities.
- **Remediation:** Planning, developing, and testing fixes or mitigations.
- **Release:** Distributing security updates and publishing advisories.
- **Post-Release:** Monitoring effectiveness and applying lessons learned.

Manufacturers implementing this document will be equipped to demonstrate due diligence in vulnerability handling, maintain product security over time, and support transparency and trust across the digital ecosystem.

1 Scope

This document specifies the requirements and activities that focus on the process aspects of vulnerability handling applicable to manufacturers of products with digital elements (hereinafter referred to as "product").

The document is intended to support compliance with the Cyber Resilience Act (CRA) Regulation (EU) 2024/2847, particularly the essential requirements outlined in Annex I, Part II.

This document, with the appropriate requirement enhancements, is applicable across all product categories. Implementing these requirements enables a manufacturer to ensure security is maintained throughout the product life cycle.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

prEN 40000-1-1, *Cybersecurity requirements for products with digital elements - Vocabulary*

prEN 40000-1-2:2025, *Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience*

3 Terms and definitions

For the purposes of this document, the terms and definitions given in prEN 40000-1-1 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <http://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

3.1

test

activity in which a system or component is executed under specified conditions, the results are observed or recorded, and an evaluation is made of some aspect of the system or component

Note 1 to entry: A test is carried out to measure or classify a characteristic or a property of an item by applying to the item a set of environmental and operating conditions and/or requirements.

[SOURCE: [Error! Reference source not found.](#), 3.21]

3.2

review

activity undertaken to determine the suitability, adequacy and effectiveness of the subject matter to achieve established objectives

[SOURCE: [Error! Reference source not found.](#), 3.3.41]

3.3

coordination

set of activities including identifying and engaging stakeholders, mediating, communicating, and other planning in support of vulnerability disclosure

Note 1 to entry: The term “coordinated vulnerability disclosure” is used to denote a disclosure process that includes coordination.

[SOURCE: [Error! Reference source not found.](#), 3.3]

3.4

upstream

handling, processes and movements of goods that occur before the organization in the supply chain takes custody of the goods

[SOURCE: [Error! Reference source not found.](#), 3.27]

3.5

downstream

handling, processes and movements of goods when they no longer are in the custody of the organization in the supply chain

[SOURCE: [Error! Reference source not found.](#), 3.10]

4 General

4.1 Structure of this document

Requirements in this document are assigned unique identifiers consisting of a three letter abbreviation for clause and for the requirement a two-letter abbreviation (“RQ” for a requirement, “RC” for a recommendation, and “PM” for a permission, all numbered independently, each starting at 01), followed by a number, separated by a hyphen.

This document supports the risk-based approach by providing requirement enhancements that are listed into the document with the acronym RE.

EXAMPLE **5.X.X [XXX-1] Title of the Section**

....

5.X.X.X Requirement

....

[XXX-X-RQ-XX] Description of a requirement

[XXX-X-RQ-XX-RE] Description of a requirement enhancement

[XXX-X-RC-XX] Description of a recommendation

[XXX-X-PM-XX] Description of a permission

4.2 Relationships with other international standards

This document uses as building blocks the following standards and technical reports:

- [Error! Reference source not found.](#) - Vulnerability disclosure - provides guidelines for manufacturers on how to process and remediate potential vulnerability reports reported by internal or external individuals or organizations. The major focus is on receiving reports about potential vulnerabilities and when distributing vulnerability remediation information to affected users.
- [Error! Reference source not found.](#) - Vulnerability handling processes - provides guidelines on how to investigate, process and resolve potential vulnerability reports.

To enhance the multi-party essence of the CVD and to capture the complexity of the supply chain and multiple stakeholder involved in the coordinated vulnerability disclosure process this document has been augmented with [Error! Reference source not found.](#)

- [Error! Reference source not found.](#) - Multi-party coordinated vulnerability disclosure and handling - clarifies and increases the application and implementation of [Error! Reference source not found.](#) and [Error! Reference source not found.](#) in multi-party coordinated vulnerability disclosure (MPCVD) settings.

NOTE [Error! Reference source not found.](#) and [Error! Reference source not found.](#) use the term “vendor” where CRA uses “manufacturer”.

The relationships between the referenced standards are shown in Figure 2, which highlights the components that were introduced or substantially modified to align with the Cyber Resilience Act essential requirements.

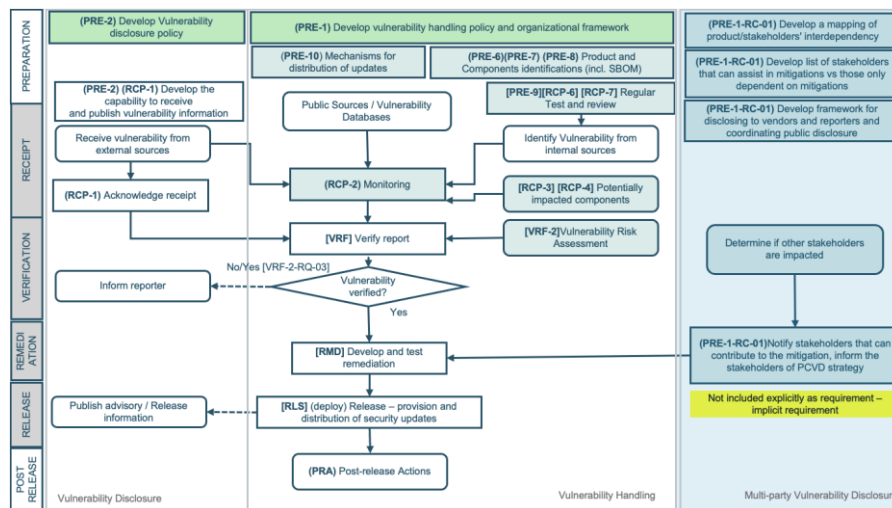


Figure 2 — Relationships between referred standards and this document

5 Vulnerability handling

5.1 General

This clause defines the key activities and requirements for vulnerability disclosure and handling, providing manufacturers with a structured foundation for designing and implementing their own processes. These processes enable manufacturers to manage communication among

stakeholders, proactively discover and collect vulnerability information and reports, and diagnose and remediate vulnerabilities before they become public, thereby preventing malicious actors from exploiting them.

5.2 [APP] Applicability (WE DECIDED TO REMOVE THIS SECTION IN WG9 MEETING IN STOCKHOLM)

Warning — This section will be removed as last one because we need to make sure that the comments will not be lost.

proposal: [PRE REAPP 20260428 Angelo](#)

5.2.1 General

The rigor applied to vulnerability handling activities follows a risk-based approach aligned with the product's risks.

5.2.1.1 REVISED: Rationale and Guidance (NL:2004)

PROPOSAL TO BE DISCUSSED

EXAMPLE This standard employs a tiered structure to ensure that the level of implementation of certain vulnerability handling processes or specific requirements are proportionate to the product cybersecurity risk { **replacement of rigor wording - DE-2351, FR-1521, IE-1867/1868, FI-1206, ES-2728** } profile { **addition of risk profile - DK-1846**}. This is achieved through the use of Requirement Enhancements (RE). {**ADDITION PROPOSED BY ANGELO - considering addition from IE-2258**}

- **Base Requirements:** Define the mandatory cybersecurity baseline process applicable to all products within the scope of this standard. {Clarification that baseline requirements always apply - **HASR2-024, HASR2-025, ES-2728, FR-1552, NL-2274**}
- **Requirement Enhancements (RE):** Provide additional technical depth, stricter performance criteria, or more rigorous documentation expectations.

An RE is not a standalone requirement but an extension of a base requirement. It is applicable only when the product's intended use, functional criticality, or systemic impact meets specific technical threshold conditions defined in Clause 5.2.2[APP-1-RQ-01].

NOTE 1: While this standard primarily defines product related process requirements applicable to any product, REs reflect cases where stricter application and verification are appropriate due to higher risk.

5.2.2 [APP-1] Requirement enhancement applicability

5.2.2.1 General

Manufacturers are normally responsible for conducting a risk assessment to assess the risks associated with the use of the product to determine the appropriate rigor for vulnerability handling.

Dependent upon the risks, there is an expectation to implement the relevant requirement enhancements in one or more of the following identified activities:

- [PRE-5-RQ-01-RE] Secure communication
- [PRE-7-RQ-03-RE] SBOM completeness

- [PRE-7-RQ-07-RE] SBOM software component hash
- [RLS-2-RQ-03-RE] Machine-readable advisories

NOTE **EDITORIAL NOTE:** CEN-CENELEC JTC13/WG9 invites feedback from the national organizations on the approach for requirement enhancements to better support the risk based approach.

5.2.2.1.1 REVISED: Rationale and Guidance (NL:2004)

NOTE CCMC -GUIDANCE - 7 April 2026

Preferred is to have a neutral form - eg - removing manufacturers

We can also mention: The risk assessment is conducted in accordance.,...

Manufacturers are ~~normally~~ {SE-1294, NL-1361, CH-2201, DE-2352, BE-1016, DK-1824} responsible for conducting a risk assessment ~~to assess the risks associated with the use~~{NL-1361} of the product **in accordance with Article 13 of Regulation (EU) 2024/2847.** ~~to determine the appropriate rigor for vulnerability handling.~~ {about rigor - DE-2351, FR-1521, IE-1867, IE-1868, FI-1206, ES-2728}

Warning — The word normally was ADDED by the CCMC editor - #969 with the following language:

"normally" added to avoid liability/legal responsibility

rigor

The risk assessment is conducted to determine if additional measures identified as requirement enhancements (RE) in this document may be applicable (**partially inspired by NL-1483, SE-1295, DK-1847, NL-1362**).

EXAMPLE **Angelo: Proposal in the section - more discursive:**

A cybersecurity risk assessment is conducted to determine if additional measures identified as requirement enhancements (RE) in this document are applicable. This assessment ensures that the proportionality of the vulnerability handling process implementation is aligned with the potential impact of a product cybersecurity failure.

5.2.2.2 Input

- Product context ([Error! Reference source not found.](#), 6.2)
- Risk assessment ([Error! Reference source not found.](#), 6.4)

5.2.2.2.1 REVISED: Input

- Product context {Removal of normative PT1 reference **DE-2353, DE-2354, BE-1521, ES-2912, HASR2-140**}

NOTE 1 An example of reference can be [Error! Reference source not found.](#), 6.2

- Manufacturer's documented cybersecurity risk assessment (Article 13 of Regulation (EU) 2024/2847 {Stand-alone applicability without PT1 dependency **FR-1552, IT-2304, CY-2687**}

NOTE 2 An example of reference can be [Error! Reference source not found.](#), 6.4

5.2.2.3 Requirement

[APP-1-RQ-01] The applicability of the requirement enhancements shall be determined based on the product risks.

NOTE **Requirement Enhancement:** Requirements marked with “RE” indicate risk-based enhancements that apply where the regulatory risk assessment determines that additional rigor is necessary.

5.2.2.3.1 REVISED: Requirement

[APP-1-RQ-01] The applicability of requirement enhancements shall be determined and documented based on the outcomes of the cybersecurity risk assessment considering the following technical criterias:

- Criticality of Function: The product’s core functionality is essential to the security of the broader system (eg. authentication systems, network protection systems)
- Criticality of Deployment (Societal Impact): The RE applie
 - Disruption of essential supply chains (e.g., energy, health, logistics).
 - Compromise of safety-critical systems.
 - Systemic risk to a high volume of downstream users/devices.
- Evidence and Documentation Rigor: Consistent with the risk-based approach, the implementation of an RE necessitates a higher level of manufacturer justification.

NOTE **Requirement Enhancement:** Requirements marked with “RE” indicate risk-based enhancements that apply where the regulatory risk assessment determines that additional rigor is necessary.

Warning — NEW REQUIREMENT PROPOSED:

[APP-1-RQ-02] Where an RE is determined to be applicable, the manufacturer shall provide a higher level of evidence in the technical documentation, demonstrating that the specific technical objectives of the enhancement have been met through verified implementation.

5.2.2.4 Output

- Statement of applicability

5.2.2.4.1 REVISED: Output

- **Statement of applicability: Documented justification of the applicability or non-applicability of each requirement enhancement identified in this standard.**{DE-2356, NL-1487}

5.2.2.5 Assessment criteria

- Evaluation of the applicability criteria based on the product context and risk assessment

5.2.2.5.1 REVISED: Assessment criteria

- Evidence exists that the applicability or non-applicability of requirement enhancements has been documented and justified based on the manufacturer's cybersecurity risk assessment. **{HASR2-026/HAS-3113, HASR2-027/HAS-3114, ES-2731, DE-2355}**
- **{MISSING SUFFICIENCY ASSESSMENT HAS-3114 (HASR2-027), ES-2731, ES-2909}**

EXAMPLE

- **Completeness:** Evidence exists that every RE identified in this standard has been evaluated for applicability.
- **Justification validity:** The documented justification for non-applicability of an RE is consistent with the identified product context and the results of the risk assessment.
- **Technical sufficiency:** For all applicable REs, the technical documentation contains sufficient detail (e.g., test reports, architectural diagrams, or SBOM exports) to verify that the enhanced security objectives are fulfilled, rather than just the base requirements.

5.3 [PRE] Preparation

5.3.1 General

The preparation phase lays the foundation for establishing appropriate vulnerability handling and disclosure processes and policies to support the subsequent phases, providing a structured, methodological approach to identify, verify, and address vulnerabilities, including communication. This phase also includes requirements such as identifying software and hardware components, focusing on creating the Software Bill of Materials (SBOM), and establishing a coordinated vulnerability disclosure and vulnerability handling policy.

5.3.1.1 REVISED: Rationale and Guidance (NL:2004)

The preparation phase lays the foundation for establishing appropriate vulnerability handling and disclosure policies, processes **and capabilities to provide** a structured, methodological approach to ~~identify, verify, and address vulnerabilities~~ (GB-2660) manage the lifecycle of the vulnerabilities, including communication.

This phase **contains** requirements related to the identification of software and hardware components, including the establishment of a Software Bill of Materials (SBOM), **plans for testing and updates**, as well as the definition of vulnerability handling and coordinated vulnerability disclosure policies. **Together, these requirements provide the necessary governance, transparency, and coordination readiness to enable an effective vulnerability handling (ADDITION ANGELO).**

5.3.2 [PRE-1] Policy on vulnerability handling (FR-1593 - Vulnerability handling policy)

Final version can be found: at <https://sd.cen.eu/documents/open/1d2d90f4-92f8-4380-b9c4-6a285ceb78ce>

[PRE PRE1 Final 20260409 angelo](#)

5.3.2.1 General

A manufacturer establishes and maintains an internal vulnerability handling policy to clearly define their approach for investigating and remediating security vulnerabilities. An additional important aspect covered is the testing strategy that should be defined to support effective and regular tests and reviews of its products. This policy forms a core part of the manufacturer's overall vulnerability handling process and is compatible with the external coordinated vulnerability disclosure policy as per 5.3.3. The intended audience for the vulnerability handling policy is the internal staff.

5.3.2.1.1 REVISED: Rationale and Guidance (NL:2004) (M64)

Warning — TO BE DELETED AND ACCOUNTED FOR:

(2) In relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;

A vulnerability handling policy defines the manufacturer's **internal governance and processes** for **monitoring (FR-1612, BE-1169)**, investigating and remediating security vulnerabilities. **(NL-1488)**

It establishes amongst others internal responsibilities, principles, decision criteria, escalation paths, and confidentiality expectations that guide the vulnerability handling activities defined in this document. (new addition from Angelo - looking at all the comments - Partially inspired by CY-2689 for adding context - WE do not want to list it all).

~~An additional important aspect covered is the testing strategy that can (DE-2384, FR-1613) be defined to support effective and regular tests and reviews of its products (FI-1179, NL-1489, BE-1374, FR-1553, NL-1192 (OBSOLETE), FR-1613 (OBSOLETE)).~~

This policy is a core part of the manufacturer's overall vulnerability handling process and is consistent with the external Coordinated Vulnerability Disclosure (CVD) policy as per 5.3.3. ~~The intended audience is internal personnel involved in vulnerability handling activities.~~

[ANGELO: this is more fluid text]

A vulnerability handling policy establishes the internal governance and structured processes required for monitoring (FR-1612, BE-1169), investigation, and remediation of security vulnerabilities (NL-1488).

Rather than just a set of rules, this policy serves as the primary internal framework that defines responsibilities, decision criteria, escalation paths, and confidentiality expectations. By providing this clarity, the manufacturer ensures that personnel involved in security activities have a consistent roadmap for action (partially inspired by CY-2689).

This policy is designed to be fully consistent with the external Coordinated Vulnerability Disclosure (CVD) policy, ensuring that once a vulnerability is handled internally, the resulting information and patches are communicated to the public in a transparent and synchronized manner.

Warning — TO BE DELETED AND ACCOUNTED FOR:

Threat that we want to cover:

- Unstructured or not formalized policy are introducing an unnecessary delay in addressing vulnerabilities.

- **Documented policy and related processes:** This allows the manufacturer to pre-allocate resources, define organizational support, and establish a predictable workflow to effectively plan and manage vulnerabilities throughout their entire lifecycle.
- **Due care:** Provide evidence of due care for the CRA compliance

5.3.2.2 Input

- Coordinated Vulnerability Disclosure policy
- 5.3.10
- Software bill of materials

5.3.2.2.1 REVISED: Input

The following inputs shall be considered when establishing and maintaining the vulnerability handling policy:

- **Coordinated Vulnerability Disclosure (CVD) policy** (see 5.3.3). The CVD policy provides the principles for receiving, acknowledging and communicating vulnerability information, which the vulnerability handling policy shall align with. (*comments from FR-1615, DK-1825, DE-2390, HAS-3115*)

NOTE (Worked in M64)

No specific order of creation is implied between the vulnerability handling policy and the coordinated vulnerability disclosure policy; only their consistency is relevant.

- **Any documented internal security governance instruments relevant to vulnerability handlings** *such as risk-assessment procedures, secure development practices, or other policies describing cybersecurity responsibilities within the organization. (Addresses IE-2259, DE-2387)*

----- TO DELETE -----

- ~~5.3.10~~ *removal accepted due to the comments from FI-1180, DK-1825, BE-1375, NL-1493, IE-2123, DE-2386/2388/2390, CH-2206, CY-2690, ES-2732, FR-1615*
- ~~Software bill of materials~~ *removal accepted due to the comments from FI-1211, BE-1143, CH-2207, NL-1369, IE-1869, DE-2387, DE-2391, GB-2662, DigitalEurope-3027.*

Warning — This is for CCMC editor to check if the resolution above providing more context to the hyperlink is acceptable.

addressing: DK-982, GB-2661, ES-2732, GB-2637, CH-2206, CY-2690, HAS-3115/HASR2-028 The hyperlink is meaningless

We noted with De Coninck Marlies that instead of copying and paste the title we can still contextualize as we did above.

5.3.2.3 Requirement

[PRE-1-RQ-01] A policy on vulnerability handling shall be created, put in place and adhered to.

NOTE 1 For additional guidance on the vulnerability handling policy, refer to [Error! Reference source not found.](#), 6.3.

[PRE-1-RC-01] An organizational framework should be created to support the activities defined in the vulnerability handling process as per *[PRE-1-RQ-01]*.

NOTE 2 For additional guidance on organizational framework, refer to [Error! Reference source not found.](#), 6.4.

[PRE-1-RQ-02] The vulnerability handling policy shall include:

- basic guidance, principles, and responsibilities for handling potential vulnerabilities in products
- measures to prevent premature disclosure of information about potential vulnerabilities before they are fixed
- a target schedule for remediation development

NOTE 3 The target schedule serves as a guide for completing the activities of remediation development, as described in 5.6.

NOTE 4 The target schedule depends on different aspects such as the complexity of the remediation to be developed, and the potential risk of the vulnerability, as assessed in 5.5.2. Additional variables include the complexity of the interactions with the supply chain and entities involved in the investigation and remediation activities.

- strategies related to the regular test and review activities, as defined in 5.3.10.

[PRE-1-RC-02] A policy on vulnerability handling should include:

- the full process description that is aligned with the expectations of this document
- the roles and responsibilities that will be assigned to handle the potential vulnerabilities in the product

NOTE 5 For additional guidance on role and responsibilities including definition of usual activities refer to [Error! Reference source not found.](#):

- *6.5 Vendor CSIRT or PSIRT*
- *6.6 Responsibilities of the product business division*
- *6.7 Responsibilities of customer support and public relations*
- *6.8 Legal consultation*
- measures to prevent premature disclosure of information about potential vulnerabilities before they are fixed, as defined in 5.3.6
- activities and criteria to define a target schedule for the remediation of the vulnerability, which depends on the embargo period, established and influenced by the complexity of the case by case situation with impacted upstream stakeholders, and on the criticality of the vulnerability and the product itself
- where known and appropriate, it is important to list the downstream stakeholders that are using the product under scope

NOTE 6 Appropriateness depends on privacy and confidentiality agreements with downstream stakeholders.

- the mapping of upstream stakeholders to support the component identification required by 5.3.8 and 5.3.9

NOTE 7 For additional guidance on roles and responsibilities in a multi-party configuration that includes definition of usual activities, refer to [Error! Reference source not found.](#), Clause 8.

[PRE-1-RQ-03] The effectiveness of the vulnerability handling process shall be monitored.

NOTE 8 For additional guidance on ways to monitor the effectiveness of the vulnerability handling process, refer to [Error! Reference source not found.](#), 7.2.

[PRE-1-RQ-04] For a timely resolution of the issues, a mapping of upstream interdependencies, including open source, is required to support the coordination and notification activities when a vulnerability is discovered.

[PRE-1-RQ-05] A policy on vulnerability handling shall support all the activities that are defined in the vulnerability disclosure policy, as described in 5.3.3.

5.3.2.3.1 **REVISED: Requirement (REVIEWED IN M64 - ACTION REQUIRED)**

[PRE-1-RQ-01] A vulnerability handling policy shall be established, documented, implemented and maintained (FR-1641, SE-1299 | DE-2410).

NOTE 1 For additional guidance on the vulnerability handling policy, refer to [Error! Reference source not found.](#), 6.3.

----- CCMC - Proposal to move this in the ANNEX ---

[PRE-1-RC-01] *An organizational framework should be created to support the activities defined within this document (M64 - GB-2663).*

NOTE 2 **The vulnerability handling policy does not stand on its own but needs to be supported by the manufacturer organization policies, roles, processes, and needs to demonstrate that the vulnerability handling processes are integrated with the organization's processes. {Inspired by DE-2398, DE-2406}**

For additional guidance on organizational framework, refer to [Error! Reference source not found.](#), 6.4.

[PRE-1-RQ-02] A vulnerability handling policy shall include at least:

- basic guidance, principles, and responsibilities for handling potential vulnerabilities in products

NOTE 3 The vulnerability handling policy define and clarify the approach, process, roles, and responsibilities for investigating, coordinating, and remediating vulnerabilities affecting the product and its components throughout the product life cycle.

For additional guidance on role and responsibilities including definition of usual activities refer to [Error! Reference source not found.](#):

- 6.5 Vendor CSIRT or PSIRT

- 6.6 Responsibilities of the product business division
- 6.7 Responsibilities of customer support and public relations
- 6.8 Legal consultation

{ partially DK-2120 }

NOTE 4 For additional guidance on roles and responsibilities in a multi-party configuration that includes definition of usual activities, refer to [Error! Reference source not found.](#), Clause 8.

- measures to prevent premature disclosure of information about potential vulnerabilities before they are fixed **as defined in the operational security clause 5.3.4 [PRE-3] {HAS-3118}**
- a target schedule for remediation development **{FR-1619, BE-1144, CY-2692, DE-2413, HAS-3120, HAS-3121, CH-2208, DE-2413, E ADDED NOTE TO BE REFINED})**

NOTE 5 ~~The~~**A (M64)** target schedule serves as a guide for completing the activities of remediation development, as described in 5.6.

PROPOSED - M64 in response to FR-1619, BE-2294, CY-2692, FI-1852, IE-2282, DE-2413, HAS-3122/HASR2-035, HASR2-033 For PRE-1-RQ-02:

The target schedule for remediation development is intended to support a **risk-based approach (CY-2692)** and does not imply fixed or predefined timelines. The target schedule may differ across products, product **types**, or categories of vulnerabilities and should be adapted to the specific circumstances of each case **(FR-1619, FI-1852). *Complex supply chains can have an impact on the target schedule (NL-1492).***

In defining an appropriate target schedule, the manufacturer may take into account, as relevant, factors such as:

- the priority assigned during the vulnerability risk assessment;
- the technical feasibility and complexity of developing and validating the remediation;
- product lifecycle constraints;
- the complexity of interactions with the supply chain and other entities involved in the remediation activities; and
- characteristics of downstream stakeholders, considered at least at category level where relevant and appropriate.

The target schedule may be defined per vulnerability or per category of vulnerabilities and may distinguish between expedited (prioritized) and non-expedited (non-prioritized) cases, where applicable **(Partially Accepting - HAS-3120/HASR2-033, ES-2737)**. The target schedule serves as a planning guide for remediation development activities and should remain proportionate to the identified risk.

The element Parent:non-normative-note: non-normative-note has not been processed

Warning — M65: All these comments are addressed by the Note 5

- **option 1:** A method to define an appropriate target schedule for remediation **(FR-1619)**

- **option 2:** A target method to define a schedule for the start of the investigation. ~~(BE-2294) (BSI – the only one that is not a fit for the section)~~
- **option 3:** A risk-based approach for determining remediation timelines, taking into account the priority assigned during vulnerability risk assessment, technical feasibility, validation requirements, and product lifecycle constraints”. **(CY-2692)**
- **option 4:** a description on how target schedule for remediation development is defined. **(FI-1852)**
- ~~**option 5:** a set of SLAs for remediation development based on the risk **(IE-2282)**~~
- ~~**option 7:** a target schedule for impact/risk/criticality assessment and start of the investigation and remediation development **(DE-2413, CH-2208)**~~
- **option 8:** For PRE-1-RQ-02, the intended downstream stakeholders must be listed at least as category of stakeholder as this is relevant for the definition of the **target schedule**. This is in line with the CRA obligation to define intended purpose and reasonably foreseeable use as part of the risk assessment, and does not necessarily mean individual customer names. **(HAS-3122/HASR2-035)**
- **HASR2-033 For PRE-1-RQ-02**, the manufacturer should define separate target schedules for "expedited" (priority) and non-expedited (non-priority) vulnerabilities, including number of calendar days. Proposed Change: add to the requirement
- strategies related to the regular test and review activities, as defined in 5.3.10.
 - **[TO BE Moved to Clause 5.3.10 OR TO CHECK IF ALREADY THERE] (NL-1499, FR-1525, FI-1181, NL-1491, BE-1268, CH-2208)**
- **Proposed Change: require the creation of a list of intended downstream stakeholders as part of the definition of the target schedule (HASR2-035)**

----- CCMC - Proposal to move this in the ANNEX ---

[PRE-1-RC-02] A vulnerability handling policy should include:

- Statements concerning the creation of processes that are aligned with this document **{DK-1987, CH-2204, NL-1494}**
- ~~the roles and responsibilities that will be assigned to handle the potential vulnerabilities in the product~~ **{ partially DK-2120 - DUPLICATE}**
- ~~measures to prevent premature disclosure of information about potential vulnerabilities before they are fixed, as defined in 5.3.6 (SE-1821)~~
- ~~activities and criteria to define a target schedule for the remediation of the vulnerability, which depends on the embargo period, established and influenced by the complexity of the case by case situation with impacted upstream stakeholders, and on the criticality of the vulnerability and the product itself~~ **(M64)**
 - **{Rephrase: FR-1621, BE-1272, SE-1822, GB-2638}**
 - **Delete: DE-2400, CH-2205, NL-2144}**
 - **DEFINE embargo period - DK-1924, DE-2401**
- where known and appropriate, it is important to list the downstream stakeholders **categories (M64)** that are using the product **type** under scope

Warning — **Rephrase:** DK-1931, DE-2394, FR-1635, DE-2392, DIGITALEUROPE-3035

Delete: IE-1952, CH-2205, DE-2409, NL-2144, FI-1451, BE-1141,

Options rephrase:

- DK-1931 - statements concerning procedures for identifying and/or contacting downstream stakeholders
- FR-1635 - activities to list the downstream stakeholders that are using the product under scope, where known and appropriate
- DE-2394 - Downstream and Upstream shall be defined
- DE-2392 -
- Where known and appropriate, it is important to list the downstream stakeholders that are using the product under scope
- Where known and appropriate, it is important to list the type of upstream stakeholders that are involved in or contributing to the product under scope
- Note: Instead of concrete individuals it can be just types of stakeholders, which are using or contributing to the product.
- DIGITALEUROPE-3035 - Rewrite NOTE 6 as:
- Appropriateness depends on privacy and confidentiality agreements with downstream stakeholders.
- the mapping of upstream stakeholders to support the component identification required by 5.3.8 and 5.3.9

EXAMPLE **PROPOSAL FROM ANGELO TO BE DISCUSSED IN M66:**

- A strategy to establish, document, and maintain relationships with **downstream stakeholders**(*from: In ISO/IEC TR 5895:2022(E) mentioned as Dependent vendors are typically downstream of mitigating vendors*), where known and appropriate

Warning — This is to be removed just for the discussion In ISO/IEC TD In ISO/IEC TR 5895:2022(E) :

- *Establishing and maintaining relationships with anticipated dependent vendors in the supply chain to prepare for the handling of a vulnerability that requires MPCVD and supportive processes.*

NOTE 7 Appropriateness depends on privacy and confidentiality agreements with downstream stakeholders.

NOTE 8 For additional elements in the policy to support further the MPVD please refer to [Error! Reference source not found.](#), Clause 7.2.2.

- Rephrase: DK-1933,FR-1622, BE-1273 Delete: DE-2399, FR-2014, BE-1142 Move to new requirement - NL-1497

To review **(DK-1931) (FR-1635)**

- the mapping of upstream stakeholders to support the component identification required by 5.3.8 and 5.3.9(**to evaluate FR-1554, FI-1216, DE-2396, NL-1499, IT-2322, GR-2953, DigitalEurope-3032, BE-1275**)

— FR-2014

Warning — Rephrase: DK-1933,FR-1622, BE-1273

Delete: DE-2399, FR-2014, BE-1142 Move to new requirement - NL-1497

DK-1931 - statements concerning procedures for identifying

DK-1993 - statements concerning procedures for identifying

FR-1622

- the mapping of upstream software stakeholders which is fulfilled by PRE-7-RQ-01
- the mapping of upstream stakeholders to support the component identification required by 5.2.9[PRE-8] Identification of hardware components

BE-1273 -The mapping of upstream software stakeholders which is fulfilled by PRE-7-RQ-3

Warning — ACTION ITEM FOR WG9: The vulnerability handling policy as at the moment is linked to the the section 8 MPCVD life cycle for each product - the invitation for the WG9 members is to reflect on this section and come out with concrete proposal on how to address the problem with : upstream and downstream stakeholders

Warning — Proposal from Angelo to discuss in M65:

- A strategy to establish, document, and maintain a list and relationship to complement the information as per 5.3.8 and 5.3.9 activities

[PRE-1-RQ-03] The effectiveness of the vulnerability handling process shall be monitored. (SEE ACTION ITEM: PT3_M65_A2)

Warning

- **Delete:** NL-2138, FR-1623, DE-2411, ES-3062
- **Rephrase and further granularity:** HAS-3123/HASR2-036, BE-1274

Proposal: The vulnerability handling policy shall be periodically reviewed and updated as necessary to ensure its continued suitability.

NOTE 9 For additional guidance on ways to monitor the effectiveness of the vulnerability handling process, refer to [Error! Reference source not found.](#), 7.2.

--- TO BE DISCUSSED M65--

---- ANGELO PROPOSED THE FOLLOWING PLEASE LOOK AT THE WARNING SECTION ----

[PRE-1-RQ-04] For a timely resolution of the issues, a mapping of upstream interdependencies, including open source, is required to support the coordination and notification activities when a vulnerability is discovered .

NOTE 10 Stakeholders may be identified at the level of stakeholder categories (e.g. dependent vendors, integrators, service providers, open-source maintainers), rather than individual organizations or persons

NOTE 11 This requirement is intended to reflect preparedness for multi-party coordinated vulnerability handling (MPCVD) as described in [Error! Reference source not found.](#), Clause 7.2.2. It focuses on policy-level considerations for coordination and communication, not on the technical completeness of dependency inventories.

NOTE 12 The detailed identification and documentation of software and hardware components and their dependencies are addressed in the component identification requirements of this document (see 5.3.8 [PRE-7] Identification of software components and 5.3.9 [PRE-8] Identification of hardware components")

NOTE 13 For completeness the MPCVD life cycle for each product is further is further described by [Error! Reference source not found.](#), Clause 8.

Warning

- **Rephrase:** SE-1138 (ACCEPTED), DigitalEurope-3032 (NOTED), BE-1352 (PARTIALY_ACCEPTED), FI-1216 (PARTIALY_ACCEPTED), DE-2405 (Accepted), GR-2953 (NOTED), GR-2989 (Accepted), CH-2211 (Partially_Accepted), BE-1275 (Noted), DK-1925 (Accepted), DE-2404 (Partially_Accepted), DK-1926 (Noted), GB-2639 (Accepted), IE-1870 (Partially_Accepted)
- **Move to another section:** NL-1499, (PARTIALY_ACCEPTED) - (eg. 5.3.8), IT-2322(PARTIALY_ACCEPTED), FI-1216 (PARTIALY_ACCEPTED), FR-1554 (Partially_Accepted), DE-2396 (Partially_Accepted)

Warning — ~~[PRE-1-RQ-04] For a timely resolution of the issues, a mapping of upstream interdependencies, including open source, is required to support the coordination and notification activities when a vulnerability is discovered.~~ {to evaluate {FR-1554, (DE-2396/2405 -rewrite to consider), NL-1499, FI-1216, IT-2322, GR-2953/2989, DigitalEurope-3032, CH-2211} (M64) -

- **Proposal to move it to 5.3.8 and 5.3.9**
- FR-1554 and **DE-2396/2405, IT-2322, NL-1499**
- **PROPOSAL FROM FI-1216**
- **[PRE-1-RQ-04]** For a timely resolution of the issues, the product dependencies to upstream software, including open source, **shall** be mapped and the responsible stakeholders identified"
- **PROPOSAL FROM GR-2953**
- Add under PRE-1-RQ-04: Such upstream interdependencies can be documented in the SBOM.
- **PROPOSAL FROM IE-1870**
- [PRE-1-RQ-01-04] To facilitate a timely resolution of issues, the product dependencies to upstream software, including open source, **shall** be identified and the responsible stakeholders identified.
- **PROPOSAL FROM DigitalEurope-3032**
- Rephrase as: "For timely resolution of issues, a monitoring of upstream interdependencies, including open source, shall be implemented."

M65: The following resolution PRE-1-RQ-04 was agreed during the M65

[PRE-1-RQ-04] To facilitate a timely resolution of issues, the product dependencies to upstream components, including open source, shall be identified and the responsible stakeholders documented.

Warning — [COMPRES] RELATED_COMMENT_ID:

Rephrase: SE-1138 (ACCEPTED), DigitalEurope-3032 (NOTED), BE-1352 (PARTIALLY_ACCEPTED), FI-1216 (PARTIALLY_ACCEPTED), DE-2405 (Accepted), GR-2953 (NOTED), GR-2989 (Accepted), CH-2211 (Partially_Accepted), BE-1275 (Noted), DK-1925 (Accepted), DE-2404 (Partially_Accepted), DK-1926 (Noted), GB-2639 (Accepted)

Move to another section: NL-1499, (PARTIALLY_ACCEPTED) - (eg. 5.3.8), IT-2322(PARTIALLY_ACCEPTED), FI-1216 (PARTIALLY_ACCEPTED), FR-1554 (Partially_Accepted), DE-2396 (Partially_Accepted)

PRIORITY-MEDIUM ACTION: PARTIALLY_ACCEPTED

RESOLUTION: The two different position were for a lack of clarity of the requirement in term of policy and operational implementation - the requirement was further clarified considering all the comments and better contextualized:

[PRE-1-RQ-04] The vulnerability handling policy shall address how relevant upstream and dependent relationships, including those involving open-source components, are identified and considered in order to support coordination and notification activities in multi-party vulnerability handling scenarios.

NOTE: This requirement is intended to reflect preparedness for multi-party coordinated vulnerability handling (MPCVD) as described in [Error! Reference source not found.](#), Clause 7.2.2. It focuses on policy-level considerations for coordination and communication, not on the technical completeness of dependency inventories.

The detailed identification and documentation of software components and dependencies are addressed in the component identification sections of this document (see [PRE-7] Identification of software components and [PRE-8] Identification of hardware components")

For completeness, the MPCVD life cycle for each product further described by [Error! Reference source not found.](#), Clause 8.

RATIONAL:

The position were :

— Rephrase

— Move to another section

Added clarification that is only policy related and the implementation is done to PRE-7 and PRE-8 These changes are in a way alligning all the positions

DISCUSSED: M6X

[PRE-1-RQ-05] A vulnerability handling policy **shall be consistent and** support **all** the activities ~~that are~~ defined in the **coordinated (BE-1026)** vulnerability disclosure policy, as described in 5.3.3. (NL-1501)

NOTE 14 Stakeholders may be identified at the level of stakeholder categories (e.g. dependent vendors, integrators, service providers, open-source maintainers), rather than individual organizations or persons

NOTE 15 This requirement reflects preparedness for multi-party coordinated vulnerability handling as described in [Error! Reference source not found.](#) in section 7.2.2, including the establishment and maintenance of relationships with anticipated dependent vendors (downstream stakeholders) in the supply chain

5.3.2.4 Output

- Policy on vulnerability handling
- List of the upstream stakeholders
- Data collection on target with the schedule remediation activities

5.3.2.4.1 REVISED: Output

The outputs consist of documented policy-level artefacts demonstrating governance, role definition, risk-based planning, review, and multi-party coordination preparedness for vulnerability handling.

Outputs shall include:

- ~~Policy on~~ Vulnerability handling policy (NOTE: to maintain consistency)
 - {GR-2954}
- ~~List of the upstream stakeholders~~

Warning — [COMPRE]

RELATED_COMMENT_ID: NL-2145, DK-1928, FI-1453, CH-2212, DigitalEurope-3029, DE-2415, BE-1276, NL-1502, DE-2416

ACTION: TBD:

- Remove: NL-2145, DK-1928, FI-1453, CH-2212, DigitalEurope-3029, DE-2415, IE-1953
- Rephrase: BE-1276, NL-1502, DE-2416
- Remove: list of the upstream stakeholders

RATIONAL:

- Product specific.
- This really depends on the resolutions of the comment

DISCUSSED: M6X

- ~~Data collection on target with the schedule remediation activities~~
- ~~{Delete: unclear, unsupported, and not based on any requirement} {FR-1644, DK-2121, BE-1021, CH-2213, ES-2741, HAS-3124}~~
 - [COMPRE]
 - RELATED_COMMENT_ID: DE-2415, FR-1644, CH-2213, IE-1953, BE-1021, FR-1644, DK-2121, CH-2213, BE-1277, CH-2209, ES-2741, HASR2-037/HAS-3124, BE-1278
 - ACTION: ACCEPTED
 - RESOLUTION:
 - Remove: DE-2415, FR-1644, CH-2213, IE-1953
 - Rephrase: BE-1021, FR-1644, DK-2121, CH-2213, BE-1277, CH-2209, ES-2741, HASR2-037/HAS-3124, BE-1278
 - Remove: Data collection on target with the schedule remediation activities
 - RATIONAL:
 - TBD
 - DISCUSSED: M6x

NOTE The vulnerability handling policy establishes governance rules guiding the activities defined in clauses 5.4 to 5.8. Operational artefacts produced during vulnerability handling (e.g. SBOM updates, component mapping, remediation data) are outputs of their respective clauses, not of PRE-1.

5.3.2.5 Assessment criteria

- Policy on vulnerability handling that covers the activities defined within this document
- Existence of a list of upstream stakeholders linked to the components integrated into the product with a completeness check using the SBOM
- Policy on vulnerability handling that includes:
 - appropriate alignment with the coordinated vulnerability disclosure
 - demonstrated organizational capabilities, roles and responsibilities to deal timely and in a systematic way in the event of a vulnerability
- Appropriate testing and review policies defined including regularity and timeline of those activities as aligned with 5.3.10
- Evidence of process monitoring for vulnerability handling effectiveness

EXAMPLE Meeting with CCMC 7 April

- keep recommendation if they bring added value
- we can create an assessment criteria only for recommendation

5.3.2.5.1 REVISED: Assessment criteria

Warning — M65: HASR2-009 - is asking for the semantically assessing the justification, but the ask that is coming from the HAS comment that the justification is sufficient is not possible for a process standard - without looking into the specific situation - the reason is that :

- process standard
- no reference material available that the WG9 can use to qualify justification - if not going into the specific

PASS/FAIL assessment shall confirm {DK-986}:

Option 1:

- *Existence of an established vulnerability handling policy* {BE-1024} that includes the element in **PRE-1-RQ-02**

Warning — [COMPRE]

RELATED_COMMENT_ID: GR-2955, BE-1024, DE-2421, DE-2421, DigitalEurope-3030, FR-1645, DE-2418

ACTION: TBD

RESOLUTION:

- GR-2955 - NOTE For microenterprises and small and medium-sized enterprises vulnerability handling aspects included in the QMS.
- BE-1024 Existence of a policy
- DE-2421 For the item “Policy on vulnerability handling that covers the activities defined within this document” mention explicitly which are the activities to be covered. Related to the “list of upstream stakeholders” rephrase so it refers to the “top-level dependencies for a given PDE” as mentioned in the CRA. Finally, either remove the reference to “roles” in the assessment criteria or modify [PRE-1-RQ-02] accordingly.
- DigitalEurope-3030 Remove the text “Policy on vulnerability handling that covers the activities defined within this document” or explicitly mentioned the activities to be covered. Change “list of upstream stakeholders” so it refers to the “top-level dependencies
- FR-1645 Two items state criterias on the same output. Proposed Change: Groupe all criterias relating to the same output together.
- DE-2418 “Policy on vulnerability handling” is added twice to the list. Proposed Change: Delete either the first or the third bullet with sub bullets.
- BE-1024 clause / not document

RATIONAL: TBD

DISCUSSED: M6x

M65

Option 2: to cover the monitoring and improvements

- Demonstrate that there is a documented process and procedure to manage changes of the elements of the vulnerability handling policy including the one that are mandate in the [PRE-1-RQ-01] (HASR2-041) - **M65** - we can generalize this

The policy has documented a target schedule and the manufacturer demonstrate that has process in place to validate that the target schedule is still realistic.

- *The policy defines the governance principles and responsibilities required in PRE-1-RQ-02* {FR-1646, DE-2421}
- *The policy includes measures to prevent premature disclosure (5.3.6)* {HAS-3118, FR-2735}
- *The policy defines a risk-based method for determining remediation timelines* {FR-1619, CY-2692, HAS-3128}
- *Evidence exists that the policy has been periodically reviewed and updated (PRE-1-RQ-03)* {HAS-3127}

NOTE 1 Missing comments to be integrated DE-2418, CH-2210

- ~~Existence of a list of upstream stakeholders linked to the components integrated into the product with a completeness check using the SBOM {FR-1647, DE-2424, SE-1311, NL-2146}~~
- ~~Policy on vulnerability handling that includes:~~
 - ~~appropriate alignment with the coordinated vulnerability disclosure~~
 - ~~demonstrated organizational capabilities, roles and responsibilities to deal timely and in a systematic way in the event of a vulnerability {NL-986, NL-1504, DE-2419}~~
- ~~Appropriate testing and review policies defined including regularity and timeline of those activities as aligned with 5.3.10 {FR-1555, NL-1505, DE-2420, DE-2422, IE-1873}~~
- ~~Evidence of process monitoring for vulnerability handling effectiveness~~ {DE-2423, BE-1481}
 - {FR-1648} - the comment is related to the effectiveness that is difficult to assess.

1 Assessment Reference

#ID - not a problem

Assessment type: Process-based, documentation-oriented

2 Assessment Objective

NOTE 2 We can say that this is covered in the rationale and guidance and be a little bit more concrete there - or have another section here

Warning — The recommendation shall not be included in the assessment criteria - but we can always have a justification.

The assessment confirms the **existence, coverage, and maintenance** of a vulnerability handling policy and related governance arrangements.

- The objective of the assessment is to confirm that the manufacturer is organisationally prepared to handle vulnerabilities in a structured, documented, and risk-based manner, consistent with the requirements of this document and prior to placing the product on the market.

3 Assessment Preparation

NOTE 3 We can say that this section is mapped with the section **input**

Assessment preparation shall be based on the **PRE-1 inputs**

4 Assessment criteria

Verify that:

- **PRE-1-RQ-01** (preferred solutions – 8 – WE can provide that only the policy exists)
 - A documented vulnerability handling policy exists.
 - The policy is established, approved, and maintained.
- **PRE-1-RQ-02**
 - *The policy defines the governance principles and responsibilities required in PRE-1-RQ-02 {FR-1646, DE-2421}*
 - Demonstrate that there is a documented process and procedure to manage changes to the elements of the vulnerability handling policy, including the ones that are mandated in the [PRE-1-RQ-01] (HASR2-041).
 - coverage of roles, safeguards, timelines, and coordination preparedness.
- **PRE-1-RQ-03**
 - Evidence that the vulnerability handling policy is periodically reviewed and updated as necessary
- **PRE-1-RQ-04**
 - The vulnerability handling policy contains a **policy-level description** of strategies and procedures for identifying and considering upstream and downstream stakeholder categories to support coordination and notification in multi-party vulnerability handling scenarios.
- **PRE-1-RQ-05**
 - Evidence that the vulnerability handling policy (see PRE-1) addresses all of the activities present in the coordinated vulnerability disclosure policy (see PRE-2)
 - NOTE: "This is understood that the activities in the VHP cover all of the activities in the CVD".

- *The policy defines the governance principles and responsibilities required in PRE-1-RQ-02 {FR-1646, DE-2421}*

5 Assessment Activities

The assessor shall:

- review the documented vulnerability handling policy;
- verify coverage of all PRE-1 requirements;
- verify internal consistency and alignment with the CVD policy.

6 Assessment Verdict (Acceptance criteria)

Warning — M65: This part can cause a substantial modifications because we did not include assessment verdict and how to define a pass and fail criteria.

- **PASS:** All assessment criteria in in this section are met
- **FAIL:** One or more assessment criteria in in this section are not met

7 Assessment Evidence

NOTE 4 We can say that this section is mapped with the section **output**

Acceptable evidence may include:

- the vulnerability handling policy document;
- version history or approval records;
- documentation showing periodic review;
- cross-references between the vulnerability handling and CVD policies.

5.3.3 [PRE-2] Policy on coordinated vulnerability disclosure (Coordinated vulnerability disclosure policy)

5.3.3.1 General

The purpose of the coordinated vulnerability disclosure policy is to communicate the manufacturer's intentions, responsibilities, and expectations regarding vulnerability disclosure. A coordinated vulnerability disclosure policy encompasses both two-party coordination (e.g. between the reporter and the manufacturer) and multi-party disclosure involving multiple stakeholders. To support this, the manufacturer develops and publishes an external coordinated vulnerability disclosure policy and ensures the related internal activities are in place to effectively coordinate the disclosure of vulnerabilities.

In addition, to prevent attackers from gaining early access to sensitive information, reporters typically notify manufacturers privately, and refrain from public disclosure until a fix is available after an agreed-upon embargo period has passed. The receipt, verification, and remediation

development stages are generally conducted within this embargo period, ensuring that vulnerabilities are addressed securely and responsibly by all the parties involved in the process.

5.3.3.1.1 **REVISED: Rationale and Guidance (NL:2004)**

The purpose of the coordinated vulnerability disclosure (CVD) policy is to communicate the manufacturer's intentions, responsibilities, and expectations regarding the coordinated disclosure of vulnerabilities. ~~A coordinated vulnerability disclosure~~**The (NL-1506)** policy encompasses both two-party coordination (e.g. between the reporter and the manufacturer) and multi-party disclosure, involving multiple stakeholders where applicable.

To support alignment in the expectations, the manufacturer develops and publishes an **external coordinated vulnerability disclosure policy** and ensures that the corresponding **internal activities and responsibilities** are in place to effectively coordinate the disclosure of vulnerabilities.

To prevent attackers from gaining early access to sensitive information, vulnerability reporters typically notify manufacturers privately and refrain from public disclosure until a fix or mitigation is available, or until an **agreed-upon embargo period** has elapsed (NL-1508, NL-1194). An embargo period can also be used to prevent accidental disclosure of sensitive vulnerability information while remediation activities are ongoing.

The stages of **receipt, verification, and remediation development** are generally conducted within the embargo period, enabling vulnerabilities to be addressed in a secure, coordinated, and responsible manner by all parties involved.

The intended audience of the coordinated vulnerability disclosure policy includes both internal stakeholders and external stakeholders.

5.3.3.2 **Input**

— Vulnerability handling policy

5.3.3.2.1 **REVISED: Input**

The following inputs shall be considered when establishing and maintaining the vulnerability disclosure policy:

— **Vulnerability handling policy** (see 5.3.2). The policy provides the principles a formal internal framework defining the processes for investigating, triaging, and remediating security flaws which the vulnerability disclosure policy shall align with.

NOTE (Worked in M64)

No specific order of creation is implied between the vulnerability handling policy and the coordinated vulnerability disclosure policy; only their consistency is relevant.

5.3.3.3 **Requirement**

[PRE-2-RQ-01] A policy on coordinated vulnerability disclosure (CVD) shall be created, published in an accessible format and adhered to.

NOTE 1 Accessibility requirements and advice can be found in [Error! Reference source not found.](#)

[PRE-2-RQ-02] A coordinated vulnerability disclosure policy shall include one or more contact mechanisms.

NOTE 2 Contact information can be available for both reporting vulnerabilities and for requesting additional information about the coordinated vulnerability program.

For additional guidance on policy elements refer to [Error! Reference source not found.](#), 9.2.2.

A list of possible contact mechanisms includes, but is not limited to:

- e-mail address;
- phone number;
- web form;
- contact information for customer service.

[PRE-2-RC-01] The contact mechanisms should provide accessibility via more than one sensory channel.

EXAMPLE The purpose of providing more than one sensory channel is to address situations in which a potential user with a writing impediment can still, for example, call a phone number to ask for and provide information.

NOTE 3 Accessibility requirements and advice can be found in [Error! Reference source not found.](#)

[PRE-2-RQ-03] Setting expectations for on-going communication shall be stated in this policy.

NOTE 4 The reference for this requirement is 5.3.5.

[PRE-2-RC-02] A vulnerability disclosure policy should include following elements:

- vulnerability report contents;
- secure communication options as detailed in 5.3.6;
- scope;
- publication;
- recognition.

NOTE 5 For additional guidance on recommended policy elements refer to [Error! Reference source not found.](#), 9.3.

[PRE-2-RC-03] A disclosure strategy should be in place to ensure that the information on vulnerability is not disclosed before it is addressed.

NOTE 6 For additional guidance on the embargo period refer to [Error! Reference source not found.](#), 5.6.8.

For additional guidance on the disclosure strategy refer to [Error! Reference source not found.](#), 7.3.2.

NOTE 7 Vulnerability disclosure requires flexibility; there is no one-size-fits-all approach. Reports, timelines, and responses can be tailored to each case and agreed upon by all stakeholders.

NOTE 8 Different embargo periods (vulnerability-by-vulnerability) can be negotiable between manufacturers and reporters, or a coordinator if involved.

5.3.3.3.1 **REVISED: Requirement**

[PRE-2-RQ-01] A policy on coordinated vulnerability disclosure (CVD) shall be created, published in an accessible format and adhered to.

NOTE 1 Accessibility requirements and advice can be found in [Error! Reference source not found.](#)

[PRE-2-RQ-0X] A coordinated vulnerability disclosure (CVD) **shall be consistent and** support the activities defined in the vulnerability handling policy as described in 5.3.2 (**HAS-3131/HASR2-04**)

[PRE-2-RC-0X] The policy on coordinated vulnerability disclosure (CVD) should include consideration facilitating explicit authorization for reporters that discovered vulnerability with no malicious intent for purposes of good faith testing. **{FR-1661, ES-3065}**

NOTE 2 For additional guidance on the third party rights refer to [Error! Reference source not found.](#), 9.4.2.

5.3.3.4 **Output**

- Policy on coordinated vulnerability disclosure

5.3.3.5 **Assessment criteria**

- Evidence of the policy on coordinated vulnerability disclosure that is published and followed, and aligned with the internal vulnerability handling policy to support its implementation
- Evidence of the policy on coordinated vulnerability disclosure that include agreements or definition of parameters necessary to estimate the embargo period during the receipt phase
- Evidence that the contact mechanisms have been published in an accessible format and consider more than one sensory channel

5.3.4 **[PRE-3] Operational security**

5.3.4.1 **General**

Information related to vulnerabilities is generally sensitive information, as vulnerabilities can be used by malicious actors. All external communication, as well as the manufacturers' internal processes, need to take operational security into account. The confidentiality controls can be lifted after remediation and advisory information has been published. Depending on the organization and its products, confidentiality controls can be as simple as marking information with TLP (Traffic Light Protocol) or be supported by technical controls like access control.

5.3.4.1.1 **REVISED: Rationale and Guidance (NL:2004)**

5.3.4.2 **Input**

- Policy on vulnerability handling
- Policy on coordinated vulnerability disclosure

5.3.4.3 Requirement

[PRE-3-RC-01] Operational security should be provided throughout the activities of receiving (5.4.2) and communicating about (5.3.5) vulnerability information or reports.

NOTE 1 For additional guidance related to this requirement, refer to [Error! Reference source not found.](#), 6.7.

NOTE 2 Operational security can be implemented in a way that maintains accessibility for submitting vulnerability reports, including the availability of an anonymous reporting mechanism.

[PRE-3-RQ-01] Limiting access to non-public vulnerability information on a need-to-know basis shall be considered.

NOTE 3 For additional guidance related to this requirement, refer to [Error! Reference source not found.](#), 7.3.

5.3.4.4 Output

- Documented security measures applied during vulnerability handling
- Documented security measures applied during coordinated vulnerability disclosure
- Evidence of the implementation of the capability to receive the reports

5.3.4.5 Assessment Criteria

- Evidence of documented security measures

5.3.5 [PRE-4] On-going communication

5.3.5.1 General

The purpose of this phase is to maintain regular communication channels during the vulnerability handling activities with relevant stakeholders, such as users, coordinators, reporters, manufacturers, open-source stewards, maintainers of non-commercial open-source projects and other stakeholders, where required. Communication can be aligned with the product's life cycle and occur in parallel with all vulnerability handling phases, rather than following a strict sequence.

5.3.5.1.1 REVISED: Rationale and Guidance (NL:2004)

5.3.5.2 Input

- policy on coordinated vulnerability disclosure

Depending on the phase of vulnerability handling, not all of these may be required or available:

- Vulnerability report from internal or external source, see section 5.4.3
- Verified vulnerability report including an initial assessment of the vulnerability and its severity, as required per 5.5.2
- Results of the risk assessment, as required per 5.5.3

- Remediation plan, as required per 5.6.2
- Remediation and/or fix, as required per 5.6.3
- Timeline

5.3.5.3 Requirement

[PRE-4-RQ-01] Communication with reporters and other stakeholders shall be established and maintained.

NOTE 1 For additional guidance on communication with reporters and other stakeholder, refer to [Error! Reference source not found.](#), 6.5.

[PRE-4-RQ-02] Communication with users shall implement accessible modes of communication.

NOTE 2 For additional guidance on accessible communication methods refer to [Error! Reference source not found.](#), 6.6.

5.3.5.4 Output

- Record of the communication with users and other relevant stakeholders

5.3.5.5 Assessment criteria

- Presence in the CVD policy on commitments related to on-going communications
- Presence of accessible modes of communication
- If reports have been submitted, evidence exists that communication with stakeholders has been performed

5.3.6 [PRE-5] Secure communication

5.3.6.1 General

The purpose of this subclause is to define secure communication mechanisms. Since vulnerability information can be exploited to attack affected systems, it is essential that such sensitive information, especially when not publicly disclosed, is communicated confidentially.

5.3.6.1.1 REVISED: Rationale and Guidance (NL:2004)

5.3.6.2 Input

- Reporting mechanism, as required per 5.4.2.

5.3.6.3 Requirement

[PRE-5-RC-01] Secure communication mechanisms should be provided throughout the activities of receiving and communicating vulnerability information or reports.

[PRE-5-RQ-01-RE] Secure communication mechanisms shall be provided and communicated to support 5.4.2.

NOTE 1 Initial contact (reporter-controlled). Because initial contact can arrive via any channel (e.g. email, social media, phone), the organization accepts the report, registers it, and offers to continue over one of the secure options when sensitive details (exploits, customer data, keys, configuration data) are required.

NOTE 2 Providing a means of secure communication is essential, but is not enforced if the reporter is unwilling or unable to support it.

[PRE-5-RC-02] Secure communication methods should support confidentiality and message integrity.

EXAMPLE

- web-based forms or applications using TLS (HTTPS)
- e-mail encryption and signing using S/MIME or OpenPGP

NOTE 3 For additional guidance on secure communication, refer to [Error! Reference source not found.](#), 5.8.

[PRE-5-RC-03] Stakeholders should have a way to report vulnerabilities anonymously.

[PRE-5-RC-04] Methods of secure communication should not disrupt the accessibility of external communication.

5.3.6.4 Output

- Documentation on the secure communication mechanism used
- Evidence of secure communication

5.3.6.5 Assessment criteria

- Presence in the CVD policy on commitments related to mechanisms of secure communication
- If reports have been submitted, evidence exists that secure communication with stakeholders has been performed

5.3.7 [PRE-6] Product identification

5.3.7.1 REVISED: [PRE-6] Product identification (M66- TO BE REMOVED)

Warning — [COMRES] Comment_ID: all in this subsection

Priority: Medium

Action:

- Noted Resolution: Based on HASR2-078 (3165) decision, the whole session PRE-6 Is removed.

Rationale:

- PRE-6 goes beyond the legal requirements
- CRA article 13.15 address product identification
- Relevant aspects are addressed already by PRE 7 and PRE 8 (HW component identification, SW component identification including SBOM)

Discussed: M66

5.3.7.2 General

This subclause describes the activities of recording relevant information to enable the product to be identifiable, for different purposes such as vulnerability handling, software bill of material generation and verification, and vulnerability information sharing and reporting.

5.3.7.3 Input

- Rules on naming and versioning conventions

5.3.7.4 Requirement

[PRE-6-RQ-01] A product shall be identifiable by providing at least the following information:

- manufacturer name;
- product name;
- (for hardware): any hardware product identifier, if applicable;
- (for software): any software product identifier, if applicable.

[PRE-6-RQ-02] If the product consists of both hardware and software, information for product identification, as per *[PRE-6-RQ-01]*, shall be provided separately.

NOTE A taxonomy of methods for identifying the product is documented in [Error! Reference source not found.](#) The resource can be found online with reference 0112/2///61360_7#AAS005#001 at the following web address https://cdd.iec.ch/cdd/iec61360-7/iec61360-7.nsf/classes/0112-2---61360_7%23AAS005

EXAMPLE Information for product identification can be provided using one or more of the following:

(for hardware)

- part number
- serial number
- batch number
- firmware version
- production date

(for software)

- software version
- release version
- build number
- software Hash Identifier (SWHID)
- release date

5.3.7.5 Output

- Record of information for product identification

5.3.7.6 Assessment criteria

- Evidence of product identification

5.3.8 [PRE-7] Identification of software components

5.3.8.1 General

This subclause describes the activities of identifying the software components that make up the product. The purpose of this identification is to enable effective vulnerability handling by ensuring that all components are known, traceable, and can be assessed for potential cybersecurity risks.

5.3.8.1.1 REVISED: Rationale and Guidance (NL:2004)

5.3.8.2 Input

- Binary artefacts
- Configuration files
- Source code
- Cybersecurity architecture and design documents ([Error! Reference source not found.](#), 7.4)
- 5.3.7
- Risk assessment ([Error! Reference source not found.](#), 6.4)

5.3.8.3 Requirement

[PRE-7-RQ-01] All software components contained in the product shall be identified and documented.

[PRE-7-RQ-02] For each component identified in [PRE-7-RQ-01], the following information shall be included:

- Software producer

NOTE 1 For open-source software, which is supported by an open-source steward, this is the name of the stewarding organization.

- Component name
- Component version

[PRE-7-RQ-03] An SBOM shall be drawn up, including **at least the top-level dependencies** that are contained in the product, as identified in [PRE-7-RQ-01].

NOTE 2 For additional guidance on top-level dependencies, refer to BSI TR-03183-2 [0](#), 8.3.1.

[PRE-7-RQ-03-RE] All the software components identified in [PRE-7-RQ-01] shall be drawn up in the SBOM to detect transitive dependencies when technically feasible.

NOTE 3 It might not always be possible to obtain the necessary information from suppliers to generate an SBOM that includes all transitive dependencies.

NOTE 4 For additional guidance on the depth and extent of the SBOM refer to [Error! Reference source not found.](#), B.3.1.3.

NOTE 5 A more granular SBOM can better support the ability to faster and more efficiently detect vulnerabilities in the components that are part of the product.

[PRE-7-RQ-04] The SBOM shall be assembled in a structured, machine-readable format.

NOTE 6 The SBOM includes the relationship of the identified software components. This includes the software components on which this software component is directly dependent, or which this software component contains.

NOTE 7 Some of the widely used machine-readable formats by software ecosystem stakeholders to generate and consume SBOMs are, for example:

- Software Package Data eXchange (SPDX) ([Error! Reference source not found.](#))
- CycloneDX

[PRE-7-RQ-05] If the software component is updated with a new build or release, a new SBOM shall be created to reflect the new version of the software.

NOTE 8 This includes software builds to integrate an updated component or dependency.

[PRE-7-RC-01] When new details about the identified components are detected or the need to correct an error in the existing SBOM is discovered, a revised SBOM should be issued.

[PRE-7-RQ-06] Metadata for the SBOM shall include:

- SBOM Author

NOTE 9 The name of the entity that creates the SBOM data for a component.

- Version
- Timestamp

NOTE 10 Timestamp is used to record the date and time of the SBOM creation and modification by the Author. For additional guidance on the timestamp format, refer to [Error! Reference source not found.](#) (e.g. 2024-05-23T13:51:37Z).

[PRE-7-RQ-07] For each component part of SBOM as [PRE-7-RQ-02], the following information shall be included:

- Information as required from [PRE-7-RQ-02]
- Dependency relationship
- Unique component identifiers

NOTE 11 Identifier(s) used to identify a component or serve as a look-up key for relevant databases.

EXAMPLE The component identifier can be *Common Platform Enumeration (CPE)*, *Package URL (PURL)*, or *SoftWare Hash IDentifier (SWHID)*. If more than one component identifier is available, all of them can be stated.

NOTE 12 SBOM information can additionally include:

— *Licence information of the component*

[PRE-7-RQ-07-RE] If the supplier provides the hash and the corresponding algorithm for the component, it shall be included in the SBOM.

NOTE 13 The original component artefact mentioned in the enhanced requirement refers to the original hash provided by the component provider.

NOTE 14 Source code hashes identify the upstream components from which the product is built, so that vulnerabilities that might be inherited can be identified. The shipped digital element can also have its own hash.

NOTE 15 In certain development models, such as those involving the integration of individual code snippets from open-source projects, it is not possible to include the hash and the corresponding algorithm in the SBOM, as no complete artefact from the original component exists.

5.3.8.4 Output

- Identified software components
- Software Bill of Materials (SBOM)

5.3.8.5 Assessment criteria

- Evidence of the SBOM in a structured machine-readable format
- Comparison of identified assets to SBOM entries to demonstrate appropriate completeness based on the risk assessment and the readiness of the organization

5.3.9 [PRE-8] Identification of hardware components

5.3.9.1 General

This clause describes the activities for identifying the hardware components used in the product that may affect its cybersecurity. The purpose of this identification is to enable effective vulnerability handling by ensuring that the relevant hardware components integrated into the product are known, traceable, and assessable for potential cybersecurity risks.

5.3.9.1.1 REVISED: Rationale and Guidance (NL:2004)

5.3.9.2 Input

- Cybersecurity architecture and design ([Error! Reference source not found.](#), 7.4)
- Risk assessment ([Error! Reference source not found.](#), 6.4)

5.3.9.3 Requirement

[PRE-8-RQ-01] Hardware components that are integrated in the product shall be identified and documented.

NOTE 1 For the specific definition of 'hardware', refer to Clause 3.

[PRE-8-RQ-02] For each identified hardware component as per [PRE-8-RQ-01], the following information shall be recorded:

- hardware producer;
- component name;
- component identifier;
- if applicable, firmware version.

NOTE 2 A taxonomy of methods for identifying the product is documented in [Error! Reference source not found.](#) The resource can be found online with reference 0112/2///61360_7#AAS005#001 at the following web address https://cdd.iec.ch/cdd/iec61360-7/iec61360-7.nsf/classes/0112-2---61360_7%23AAS005

NOTE 3 Further available information can be recorded, such as:

- part number;
- serial number;
- batch number;
- component version;
- production date;
- hardware revision.

5.3.9.4 Output

- List of hardware components and related information recorded

5.3.9.5 Assessment criteria

- Evidence of the list of identified hardware components and related information
- Comparison of identified assets to the list of hardware components entries to demonstrate appropriate completeness based on the risk assessment

5.3.10 [PRE-9] Planning regular test and reviews

5.3.10.1 General

Regular testing and review are necessary to maintain a product's security. Depending on the risks associated with the product's use, specific activities such as regular vulnerability scanning and

other testing and review should be planned. This plan, including the schedule and actions, is needed for the security maintenance of a product, taking into account the product's context.

5.3.10.1.1 REVISED: Rationale and Guidance (NL:2004)

Warning — TO BE DELETED AND ACCOUNTED FOR:

Refresh on what essential requirement part we want to cover.

- (3) apply **effective** and **regular tests and reviews** of the security of the product with digital elements;

Regular testing and review are necessary to maintain a product's security. Depending on the risks associated with the product's use, specific activities such as regular vulnerability scanning and other testing and review ~~should~~**can** (DE-2361) be planned. This plan, including the schedule and actions, is needed for the security maintenance of a product, taking into account the product's context.

NOTE This information supports [Error! Reference source not found.](#) clause 7.2.

[ANGELO: this is more fluid text]

Regular testing and reviews are fundamental to maintaining a product's security posture against an evolving threat landscape. To fulfill the mandate for effective and regular security assessments, the manufacturer establish a structured plan that defines the scope, frequency, and methodology of testing. This planning phase ensures that security maintenance is proactive rather than reactive, tailored to the product's specific context, intended use, and associated risks.

By formalizing a test and review plan, the manufacturer mitigates the risk of latent vulnerabilities—security flaws that emerge after the product is on the market due to new exploitation techniques or changes in the operational environment.

Warning — TO BE DELETED AND ACCOUNTED FOR:

Threat that we want to cover:

- The cybersecurity threat landscape is constantly evolving; therefore, the risks associated with a product do not remain static after it is placed on the market. Without a documented and formalized test and review plan, a product is left exposed to detectable risks that could have been identified through standard security practices. A lack of planning leads to a reactive posture, where vulnerabilities are only discovered after they have been exploited in the field.
- **Structured approach to determine the operational risk:** implementing a structured approach to security testing allows the manufacturer to systematically "look for trouble" before an exploit window is opened. By defining a plan that includes regular vulnerability scans and security reviews, the manufacturer transitions from a state of uncertainty to one of managed operational risk. Furthermore, the requirement to **periodically improve the plan** ensures that the testing methodologies remain relevant and effective against emerging attack vectors, maintaining the product's resilience throughout its entire lifecycle.

5.3.10.2 Input

- Product context ([Error! Reference source not found.](#), 6.2)
- Cybersecurity architecture and design ([Error! Reference source not found.](#), 7.4)
- Product cybersecurity requirements ([Error! Reference source not found.](#), 7.3)
- Risk assessment ([Error! Reference source not found.](#), 6.4)

- Product cybersecurity verification and validation including test cases and methodologies ([Error! Reference source not found.](#), 7.6)

5.3.10.2.1 REVISED: Input

The following inputs shall be considered when planning regular tests and reviews:

- **Product Context:** Defines the operational environment and intended use (e.g., consumer vs. industrial/critical infrastructure). This determines the required **frequency** of reviews and the acceptable level of disruption during testing.

NOTE 1 A possible reference can be found for example in [Error! Reference source not found.](#), 6.2

- **Cybersecurity architecture and design:** Provides the technical map of the product's attack surface and internal security boundaries. This is used to define the **scope** and ensure all critical interfaces and security enforcements are targeted.

NOTE 2 A possible reference can be found for example in [Error! Reference source not found.](#), 7.4

- **Product cybersecurity risk assessment:** Includes the **Threat Model** and prioritizes the **testing depth**. Because resources are finite, the risk assessment highlights which "high-impact" vulnerabilities require deep manual penetration testing versus where automated scanning is sufficient.

NOTE 3 A possible reference can be found for example in [Error! Reference source not found.](#), 6.4

- **Product Cybersecurity verification and validation:** Provides the baseline **methodologies and tools** used during the development phase. These serve as the foundation for regression testing to ensure that the product's security functions continue to operate correctly throughout the maintenance phase.

NOTE 4 A possible reference can be found for example in [Error! Reference source not found.](#), 7.6

5.3.10.3 Requirement

[PRE-9-RQ-01] A risk-based security test and review plan shall be created. The plan shall include schedules and frequency of specific tests and reviews, and be appropriate to the assessed risks of the use of the product.

NOTE 1 For additional guidance on security test and review activities, refer to [Error! Reference source not found.](#), 7.6.

NOTE 2 A plan can be designed for an individual product, a product class or a product portfolio.

NOTE 3 The regularity of test and review activities is impacted by product life cycle considerations, changes in the risk level and the threat landscape, and incidents.

[PRE-9-RQ-02] A security test and review plan shall consider at least the following aspects:

- product context;
- cybersecurity architecture and design;
- product cybersecurity requirements;
- risk assessment;

- test cases and test methodologies.

NOTE 4 Security testing considers updates in technology and knowledge of vulnerabilities and threats.

[PRE-9-RQ-03] Security reviews shall consider at least the following sources:

- standards and publications describing the state-of-the-art in cybersecurity;
- changes in the threat landscape applicable to the product;
- vulnerabilities found in the product and its components;
- vulnerabilities found in similar products and their components; or
- information about the practical conditions of use as obtained by customer feedback, for example, due to support cases.

[PRE-9-RQ-04] A security test and review plan shall be maintained based on the results of performed tests and reviews.

5.3.10.4 Output

- Security test and review plan, including, if applicable, its updates

5.3.10.5 Assessment criteria

- Evidence of the existence of the security test and review plan
- Evidence of the elements of the security test and review plan being performed as planned

5.3.11 [PRE-10] Mechanisms for distribution (of updates related informations (DE-2377))

[PRE PRE10 Final 20260501 angelo](#)

5.3.11.1 General

This subclause clarifies the preparation steps that enable the manufacturer to provide information and distribute security updates. The update mechanisms can include both manual and/or (semi-)automatic updates.

These mechanisms include, for example, websites for publishing information and the infrastructure required to enable automatic security update distribution.

5.3.11.1.1 REVISED: Rationale and Guidance (NL:2004)

Warning — TO BE DELETED AND ACCOUNTED FOR:

Refresh on what essential requirement part we want to cover.

(7) provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, in an automatic manner;

(8) ensure that, where security updates are available to address identified security issues, they are disseminated without delay and, unless otherwise agreed between a

manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.

This subclause clarifies the preparation steps that enable the manufacturer to **distribute securely updates and related (advisory messages)**. ~~The update mechanisms can include both manual and/or (semi-)automatic updates.~~ **The update mechanisms can include both manual and/or automatic distribution of updates. (DE-2376, IE-1885, FR-1564, FI-1234).**

These mechanisms include, for example, websites for publishing information and the infrastructure required to enable automatic security update distribution.

NOTE The activities described in this section are described by [Error! Reference source not found.](#) clause 7.7 (NL-2018)

[ANGELO: this is more fluid text]

This subclause outlines the preparatory steps necessary for the secure distribution of updates and their accompanying security advisories.

To ensure comprehensive coverage, distribution mechanisms may encompass manual, semi-automatic, or fully automatic processes.

These include the technical infrastructure required for automated delivery as well as accessible platforms, such as dedicated websites or similar means, for the publication of security information.

Warning — TO BE DELETED AND ACCOUNTED FOR:

Threat that we want to cover:

- compromised update process and update infrastructure allowing malware or undesired software or hardware components to be manipulated.
- **Mitigating Compromised Infrastructure:** By requiring cryptographic verification at the product level, the infrastructure acts as a "trust anchor," ensuring that even if a distribution server is breached, the product will reject unsigned or maliciously modified files.
- Downstream are not informed timely and effectively leading to an unnecessary increase of the exploit window
- **Mitigating Communication Delays:** By leveraging automated distribution and standardized advisory messages, the "exploit window" is reduced by removing the manual lag between a patch being ready and a patch being applied.

5.3.11.2 Input

- Product update mechanisms supported and related documentation

5.3.11.2.1 REVISED: Input

The following inputs shall be considered when establishing the distribution mechanisms:

- **Architectural Documentation:** Details of the update protocol, infrastructure (e.g., CDN), and delivery system design.
- **Operational Context:** Information regarding the operational environment, intended use, and connectivity characteristics (e.g., critical infrastructure constraints).

Warning — M68:

- Example: could be something like update protocol considerations, CDN consideration.
- We can say architecture and mechanisms supporting the distribution of updates
- We need the following:
- product context and operational environment
- operational conditions
- intended use

5.3.11.3 Requirement

[PRE-10-RQ-01] A mechanism shall be provided to distribute security updates in a secure manner in accordance with prEN 40000-1-2:2025, 7.7.2.

[PRE-10-RQ-02] A mechanism for the distribution of security information for the product shall be provided.

NOTE This includes mechanisms for providing advisories, release notes, installation information, and notifications.

[PRE-10-RQ-03] Where applicable, mechanisms for automatic distribution of security updates for product shall be provided.

5.3.11.3.1 REVISED: Requirement

[PRE-10-RQ-01] A mechanism shall be provided to distribute security updates in a secure manner (HAS-3192, digitaleurope-3048, ES-2809, DE-2379, DE-2378). To ensure the integrity and authenticity of the distribution process, the following elements, where applicable, are included:

- Processes that ensure security updates are protected against manipulation before the software update process is initiated.
- The update processes used are protected to prevent them being compromised, including development of the update delivery system.
- Processes used to verify and validate integrity and confidentiality functionality used in the distribution infrastructure and in the product are appropriate.
- Infrastructure designed to ensure that security updates are accessible to relevant downstream stakeholders without delay upon release.

Warning — TO BE DELETED:

Reference to - UNECE WP29 R156 (March 2021) – Road Vehicles – Software Update

- June 2024 <https://unece.org/transport/documents/2021/03/standards/unregulation-no-156-software-update-and-software-update>
- 7.1.3.1. The process they will use to ensure that software updates will be protected to reasonably prevent manipulation before the update process is initiated.;
- 7.1.3.2. The update processes used are protected to reasonably prevent them being compromised, including development of the update delivery system;

- 7.1.3.3. The processes used to verify and validate software functionality and code for the software used in the vehicle are appropriate.

Another nice reference can be:

- <https://www.iso.org/obp/ui/en/#iso:std:iso:24089:ed-1:v1:en>

NOTE 1 For additional guidance on distribution of update and principle refer to [Error! Reference source not found.](#), 7.7.2

NOTE 2 **M69 Decision - add the following note:**

The preparation of distribution mechanisms may also be relevant for hardware components, including immutable software/firmware embedded within a hardware component.

Warning — M68: We should definitely still address the granularity of this requirement as HAS-3191 (Francesco to investigate how and if it is this touched in 62443)

We should investigate how to incorporate and expand concepts from PT1 7.7.2 that cover also secure distribution even with more details than we are doing it such as:

[CLA-06-RQ-02] The activities of production and distribution of digital software products shall, where appropriate to the risk assessment and cybersecurity context of the product, include the following measures:

- Authentication for accessing protected areas of the online hosting platform;
- Protection of the integrity of distribution artefacts, considering both transit and storage;
- Mechanisms that ensure the authenticity of distribution artefacts.

M68: we would like to add to add the clarification that the manufacturer should create the plan not only considering secure distribution of the software that may be implicit but also on the hardware components that it is not explicitly mentioned into the requirement. (Joakim and to make it more structured than these lines taken in the meeting)

Reference to IETF SUIT – Software Updates for IoT

- <https://datatracker.ietf.org/group/suit/about/>

Reference to the enisa document for idea:

- <https://www.enisa.europa.eu/sites/default/files/publications/WP2019%20-%20O.1.1.1%20Good%20practices%20for%20security%20of%20IoT.pdf>

Other presentation:

- https://globalplatform.org/wp-content/uploads/2024/06/2_IRA-McDonald-OTA-Standards-Update.pdf

[PRE-10-RQ-02] One or several mechanisms for the distribution of security information for the product shall be provided (BE-1309, FR-1610). These mechanisms ensure that stakeholders are informed of vulnerabilities and mitigations through the following:

- Providing security advisories, release notes, and specific installation instructions that allow users to understand the impact and the steps required for mitigation.

- Establishing channels (e.g., email alerts, in-app notifications, or automated RSS/security feeds) to alert relevant stakeholders to the availability of critical security updates without delay.
- where applicable, providing security information in standardized, machine-readable formats to facilitate automated vulnerability management by downstream business users.
- Ensuring that the relevant advisory information is directly accessible or linked at the point of update distribution to prevent information gaps during the patching process.

NOTE 3 This includes mechanisms for providing advisories, release notes, installation information, and notifications. Way of publishing the information can include an implementation such as a dedicated portal.

Warning — This requirement was introduced to satisfy: accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.

OPTION 1:

[PRE-10-RC-01] Where applicable, automatic distribution mechanisms of security updates for product shall be provided. (HAS-3114, DK-1839)

OPTION 2:

[PRE-10-RQ-03] Where automatic security update is applicable, a mechanism for automatic distribution shall be provided. (HAS-3114, DK-1839). This mechanism includes:

- Processes that ensure security updates are distributed automatically with the related required infrastructure and design to support such function.
- Configuring the product to receive and apply security-critical updates automatically by default, ensuring immediate mitigation of known vulnerabilities.
- Providing clear settings that allow users to see the status of automatic updates and, where appropriate for the product type, toggle or schedule these updates.
- Ensuring the automatic process includes checks to prevent installation during critical operations and provides recovery options in the event of a failed update.

Warning — M68: we plan to have it as A REQUIREMENT.

- The outcome of the discussion is to reject **HAS-3114, DK-1839** because the intention of the requirement was to support this part of the essential requirement - so we want to keep it as requirement - and rephrase it
- **(7) provide for mechanisms to securely distribute updates** for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, **in an automatic manner**;
- We also believe that anyway we should add more granularity.

Where applicable is dependend from the risk assessment and need to consider the connectivity characteristics and expectations of the product intended use and operational condition. A product in a critical infrastructure with safety related functionality, it is generally not appropriate to have an automatic update, hence the related need of an automatic distributions.

- The definition of the RDPS is given by the legal text and future Annex R - we can revise this after we integrate the RDPS definition or cross-vertical outcome

Note to add:

- automatic distributions and automatic updates doesn't not imply automatic installation.
- Automatic distribution and automated update download doesn't mean automatic update installation

Look: OPTION 1: <https://datatracker.ietf.org/doc/rfc9019/>

5.3.11.4 Output

- Documentation on the distribution mechanisms for information and security updates.

5.3.11.4.1 Revised: Output

- Documentation on the secure distribution mechanism for security updates.
- Documentation on the distribution of security information.

5.3.11.5 Assessment criteria

- Evidence of capability to distribute updates and information in a secure manner.

5.3.11.5.1 Revised: Assessment criteria

- Evidence of capability to distribute updates in a secure manner with related process and implementation
- Evidence of capability to distribute advisory messages.
- Evidence of capability to distribute updates, where applicable also in an automated fashion

5.4 [RCP] Receipt

5.4.1 General

The receipt phase outlines requirements for monitoring both internal and external sources, as well as for receiving vulnerability reports, including those derived from testing and monitoring, submitted by various stakeholders.

In this phase, the manufacturer actively monitors publicly available sources for vulnerability disclosures or information that may affect its products. Upon receiving relevant vulnerability reports or information, the data are compared against the SBOM and the list of hardware components integrated in the product. By cross-referencing these sources, the manufacturer can efficiently identify any potentially affected components or products.

This phase also covers the initial assessment activities needed to identify potentially affected components. Essential to this includes activities related to regular tests and internal reviews to proactively discover new vulnerabilities.

5.4.1.1 REVISED: Rationale and Guidance (NL:2004)

5.4.2 [RCP-1] Capability to receive reports

5.4.2.1 General

The purpose of establishing the capability to receive vulnerability reports and related information is to provide researchers, users, and other interested stakeholders with mechanisms for timely reporting that are available and accessible. Publicly available reporting interfaces considering different sensory channels are essential to facilitate the prompt sharing of vulnerability information.

5.4.2.1.1 REVISED: Rationale and Guidance (NL:2004)

5.4.2.2 Input

- Policy on coordinated vulnerability disclosure

5.4.2.3 Requirement

[RCP-1-RQ-01] A publicly accessible reporting mechanism facilitating accessible modes as per 5.3.3.3PRE-2-RC-01 shall be provided to enable the receipt of vulnerability information or reports.

NOTE 1 For additional guidance on mechanisms for receiving vulnerability information or reports, refer to [Error! Reference source not found.](#), 6.2.2, which includes:

- web-based submission forms;
- bug or issue tracking systems;
- dedicated vulnerability reporting services;
- email addresses—preferably aliases, mailing lists, or role-based accounts that are not tied to a specific individual;
- phone number or similar.

An additional consideration can be to include also a security.txt file in accordance with [Error! Reference source not found.](#)

NOTE 2 For additional guidance on accessibility requirements, refer to [Error! Reference source not found.](#), which is already part of the accessibility consideration present in [Error! Reference source not found.](#)

[RCP-1-RQ-02] A mechanism shall be in place to track reported vulnerabilities with the use of an identifier or tracking number.

NOTE 3 For additional guidance on mechanisms for receiving vulnerability information or reports, refer to [Error! Reference source not found.](#), 6.2.4.

The support for an identifier, label, or tracking system would enable easy traceability of the report during on-going communications with stakeholders within the scope of vulnerability handling and disclosure activities.

[RCP-1-RQ-03] A receipt of a potential vulnerability report shall be acknowledged within a time frame that is established and declared based on the coordinated vulnerability disclosure policy.

NOTE 4 For additional guidance on mechanisms for acknowledgement of received vulnerability information or reports, refer to [Error! Reference source not found.](#), 6.2.5.

[RCP-1-RC-01] Reports should be accepted even if they use less secure mechanisms as provided by 5.3.6.

5.4.2.4 Output

- Publicly available reporting mechanisms in accessible formats and accessible modes of communication
- One or multiple documented reporting mechanisms
- If a vulnerability was reported, it is expected to have evidence of the received report with the assigned tracking number or identifier

NOTE Reception of a confirmation demonstrates successful two-way communication

5.4.2.5 Assessment criteria

- Evidence of a publicly available reporting mechanism that is accessible
- Evidence of stored reports and the assigned tracking identifier, if a vulnerability was reported

5.4.3 [RCP-2] Monitoring

5.4.3.1 General

This subclause outlines the monitoring activities for gathering vulnerability information. It involves tracking public sources and receiving information from private sources to identify potential vulnerabilities that could impact the product.

5.4.3.1.1 REVISED: Rationale and Guidance (NL:2004)

5.4.3.2 Input

- Internal and external sources for vulnerability information

5.4.3.3 Requirement

[RCP-2-RQ-01] Vulnerability information or reports from internal and external sources shall be monitored.

NOTE 1 It is preferable to have automation in place for monitoring activities.

[RCP-2-RQ-02] The minimum list of sources that shall be used is:

External sources

- EU Vulnerability Database
- Reported vulnerabilities (5.4.2)

Internal sources

- Regular testing 5.4.7
- Regular review 5.4.8

[RCP-2-RQ-04] The list of third-party components shall be monitored for end of support and usage.

NOTE 2 For open-source projects without an end-of-support date, this is typically determined by assessing whether the project is still actively maintained.

5.4.3.4 Output

- Record of relevant vulnerability information
- List of the selected internal and external sources monitored

5.4.3.5 Assessment criteria

- Evidence of a list of internal and external sources monitored
- Evidence of pertinent vulnerability record information

5.4.4 [RCP-3] Potentially impacted software components

5.4.4.1 General

This clause describes the activities for comparing the product's identified software components with incoming vulnerability information. Optionally, it is possible to automate this using the SBOM.

5.4.4.1.1 REVISED: Rationale and Guidance (NL:2004)

5.4.4.2 Input

- Vulnerability information from 5.4.3
- List of identified software components 5.3.8
- Software Bill of Materials from 5.3.8

5.4.4.3 Requirement

[RCP-3-RQ-01] Potentially affected software components shall be identified based on vulnerability information collected from 5.4.3.

NOTE Automation is possible considering the SBOM.

5.4.4.4 Output

- List of potentially impacted software components with related vulnerability information

5.4.4.5 Assessment criteria

- Evidence that identification activities have been performed
- Evidence of the identified potential vulnerabilities in the software components, if applicable.

5.4.5 [RCP-4] Potentially impacted hardware components

5.4.5.1 General

This subclause describes the activities for comparing the product's hardware component list with received vulnerability reports to identify potentially impacted hardware components.

5.4.5.1.1 REVISED: Rationale and Guidance (NL:2004)

5.4.5.2 Input

- Vulnerability information from 5.4.3
- List of identified hardware components 5.3.9

5.4.5.3 Requirement

[RCP-4-RQ-01] Potentially affected hardware components shall be identified based on vulnerability information collected from 5.4.3.

5.4.5.4 Output

- List of potentially impacted hardware components with related vulnerability information

5.4.5.5 Assessment criteria

- Evidence that identification activities have been performed
- Evidence of the identified potential vulnerabilities in the hardware components, if applicable.

5.4.6 [RCP-5] Coordinator involvement

5.4.6.1 General

The purpose of this phase is to support transparent, timely communication by actively engaging with a coordinator. While optional, a coordinator is especially helpful when vulnerabilities affect multiple manufacturers or when direct communication between the stakeholders is complex or not feasible.

5.4.6.1.1 REVISED: Rationale and Guidance (NL:2004)

5.4.6.2 Input

- Coordinated vulnerability handling policy

- Coordinated vulnerability disclosure policy

5.4.6.3 Requirement

[RCP-5-RC-01] A coordinator should be assigned and involved in the vulnerability handling process, where appropriate.

NOTE For additional guidance on coordinator involvement, refer to [Error! Reference source not found.](#), 5.5.5 and 6.6, and for the coordinator role definition refer to [Error! Reference source not found.](#), Clause 8.

5.4.6.4 Output

- Assigned coordinator role, where appropriate

5.4.6.5 Assessment criteria

- Where appropriate, evidence that a coordinator was assigned and involved during the vulnerability handling process

5.4.7 [RCP-6] Performing regular tests

5.4.7.1 General

Regular testing helps maintain the security posture. Some testing methods are described in [Error! Reference source not found.](#), 7.6. The selection of appropriate tests and their schedules are dependent upon the product risk-based criteria related to the potential negative impact of vulnerabilities on the product's security posture over time, as documented in 5.3.10.

5.4.7.1.1 REVISED: Rationale and Guidance (NL:2004)

5.4.7.2 Input

- Security test and review plan (5.3.10)
- Cybersecurity verification and validation as defined by [Error! Reference source not found.](#), 7.6

5.4.7.3 Requirement

[RCP-6-RQ-01] Security testing shall be performed according to the security test and review plan.

NOTE For additional guidance on regular security testing refer to [Error! Reference source not found.](#), 7.6.

5.4.7.4 Output

- Security test results

5.4.7.5 Assessment criteria

- Evidence of security tests being performed as planned

- Evidence of security test results

5.4.8 [RCP-7] Performing regular reviews

5.4.8.1 General

Maintaining a product's security is an ongoing task. This includes performing security tests throughout the product's support period. It also includes activities to reassess the threats and risks posed to the product due to changes in cybersecurity attack techniques or the way the product is used in practical conditions.

The needs regarding these regular tests and reviews depend on the type of product and its use. A simple product developed on demand for a specific customer and purpose, as an individual unit, might require very few actions, while a more complex product supplied in large quantities for exposure to the Internet might require stringent monitoring.

The security risk a product is exposed to is not static. It changes as attack methods or the threat landscape evolves. This can, for example, include knowledge of cryptographic algorithms' strengths.

It can also turn out that the product context is not correctly described. For example, the product's use or operational environment may differ from the description during practical use.

5.4.8.1.1 REVISED: Rationale and Guidance (NL:2004)

5.4.8.2 Input

- Security test and review plan
- Product context ([Error! Reference source not found.](#), 6.2)
- Cybersecurity architecture and design ([Error! Reference source not found.](#), 7.4)
- Information and updates about threat landscapes and the state-of-the-art in cybersecurity
- Information about cybersecurity issues found in the product
- Information about practical conditions of use of the product
- Risk assessment ([Error! Reference source not found.](#), 6.4)

5.4.8.3 Requirement

[RCP-7-RQ-01] Security reviews shall be performed according to the security test and review plan.

NOTE 1 For additional guidance on regular security reviews, refer to [Error! Reference source not found.](#), 6.7.

[RCP-7-RQ-02] The assumptions and all inputs of the product cybersecurity risk assessment shall be reviewed periodically (at least once a year), even if the product design does not change.

NOTE 2 For additional guidance on regular review, refer to:

- [Error! Reference source not found.](#), 6.7
- [Error! Reference source not found.](#), 7.2

5.4.8.4 Output

- Results of security reviews
- Resulting updates of the security test and review plan, if applicable

5.4.8.5 Assessment criteria

- Evidence of reviews being performed based on the information source defined
- Evidence of updates to the security test and review plan, if applicable

5.5 [VRF] Verification

5.5.1 General

The verification phase, often referred to as triage, includes requirements for determining whether the reported vulnerability affects the product. It also includes requirements for prioritizing the vulnerability based on vulnerability risk assessment activities.

The primary objective of this phase is to assess the validity, reproducibility, and applicability of the reported vulnerability. During this phase, the received information is reviewed to determine whether it is complete and whether the vulnerability is genuine and applicable to the product in question. If a vulnerability is assessed as relevant, the security risk analysis is performed to determine whether the risk associated with the vulnerability is to be mitigated and, if so, with what priority.

NOTE 1 During Multi-party coordinated vulnerability (MPCVD) consider the guidance provided by [Error! Reference source not found.](#), 9.2.

NOTE 2 Whereas *[VRF-1] Initial assessment and verification* and *[VRF-2] Vulnerability risk assessment* are separated, all the activities listed can occur in parallel rather than in a sequential order.

5.5.1.1 REVISED: Rationale and Guidance (NL:2004)

5.5.2 [VRF-1] Initial assessment and verification

5.5.2.1 General

The clause describes the initial assessment and verification of the vulnerability report. The primary objective of this phase is to assess the validity, reproducibility, and applicability of reported vulnerabilities. The manufacturer evaluates the credibility and information provided in the report, attempts to reproduce the issue, assesses its impact on the affected product, and assesses the severity of the vulnerability. This step ensures that only verified vulnerabilities proceed to the security risk assessment.

5.5.2.1.1 REVISED: Rationale and Guidance (NL:2004)

5.5.2.2 Input

- Vulnerability information from 5.4.3
- Product security architecture and design, see [Error! Reference source not found.](#), 7.4
- List of software and hardware components, see sections 5.3.8 and 5.3.9
- Product context, see [Error! Reference source not found.](#), 6.2
- Product risk assessment, see [Error! Reference source not found.](#), 6.4

5.5.2.3 Requirement

[VRF-1-RQ-01] More information shall be requested from the reporter if the available information is insufficient.

[VRF-1-RQ-02] An assessment of the vulnerability shall be performed.

NOTE For additional guidance related to this requirement, refer to [Error! Reference source not found.](#)

- 7.1.4 a)
- 7.1.4 b)
- 7.1.4 c)
- 7.1.4 d)

5.5.2.4 Output

- Documentation on processing the vulnerability information

NOTE This can include:

- Rationale for vulnerabilities that were determined as not applicable
- A tracked, verified vulnerability report including an assessment of the vulnerability and its severity

5.5.2.5 Assessment criteria

- Evidence that activities of vulnerability investigations have been performed
- Evidence that information and status are tracked as required by 5.4.3
- Evidence exists that the severity has been determined

5.5.3 [VRF-2] Vulnerability risk assessment

5.5.3.1 General

This clause describes the activities of conducting a risk assessment to determine the potential risk posed by a verified vulnerability, thereby prioritizing the vulnerability handling process. The risk assessment is based on the product's established risk management framework, ensuring that the results are consistent with the overall risk evaluation methodology applied to the product [Error! Reference source not found.](#)

5.5.3.1.1 REVISED: Rationale and Guidance (NL:2004)

5.5.3.2 Input

- Verified vulnerability report, including an assessment of the vulnerability and severity.
- Risk assessment ([Error! Reference source not found.](#), 6.4)

5.5.3.3 Requirement

[VRF-2-RQ-01] The risk introduced by the vulnerability shall be assessed in accordance with prEN 40000-1-2:2025, 6.4.

[VRF-2-RQ-02] The priority shall be assigned to the vulnerability based on the risk assessment referenced in [VRF-2-RQ-01] and the product risk profile.

NOTE 1 For additional guidance related to the prioritization, refer to [Error! Reference source not found.](#), 7.1.4 e)

[VRF-2-RQ-03] If the determination of the risk of the vulnerability as per [VRF-2-RQ-02] exceeds the defined threshold by the manufacturer's risk assessment, the resolution of the vulnerability shall be expedited.

NOTE 2 *In relation to the expedited definition within this document*

The process of accelerating one or more vulnerability handling activities (e.g. remediation development, testing, release) outside the normal update cycle.

[VRF-2-RQ-04] If the vulnerability information source is from a coordinated vulnerability disclosure, then the reporter shall be informed about the results of the verification.

NOTE 3 For additional guidance related to this requirement refer to [Error! Reference source not found.](#), 7.1.4 f).

NOTE 4 If the vulnerability information relates to a third-party component, then the person or entity manufacturing or maintaining that component can be informed about the results of the verification with respect to that component.

5.5.3.4 Output

- Documented outcome of the priority assessment
- Communication with the reporter, if applicable

5.5.3.5 Assessment criteria

- Evidence of the communication with the reporter, if applicable
- Evidence of prioritization of the vulnerability

5.6 [RMD] Remediation

5.6.1 General

This phase includes decision making activities to mitigate cybersecurity risks associated with the verified vulnerability. This includes identifying appropriate fixes, planning, development, testing for effectiveness and compatibility, and preparing updates or mitigations for deployment.

NOTE During multi-party coordinated vulnerability (MPCVD) consider the guidance provided by [Error! Reference source not found.](#), 9.3.

5.6.1.1 REVISED: Rationale and Guidance (NL:2004)

5.6.2 [RMD-1] Remediation decision

5.6.2.1 General

This phase includes the decision-making activities for mitigating the cybersecurity risks related to the verified vulnerability. It involves selecting and assessing risk remediation measures, evaluating their feasibility, and considering the potential impact on the product, users, and other stakeholders. Based on this analysis, the manufacturer determines the most appropriate remediation, which can include an update, intermediate mitigation, or a justified decision to defer or decline remediation.

5.6.2.1.1 REVISED: Rationale and Guidance (NL:2004)

5.6.2.2 Input

- Prioritized vulnerabilities as per 5.5.3

5.6.2.3 Requirement

[RMD-1-RQ-01] A decision on how to remediate the vulnerability shall be taken.

NOTE For additional guidance related to the remediation decision requirement, refer to [Error! Reference source not found.](#), 7.1.5 a).

[RMD-1-RQ-02] In accordance with the decision in [RMD-1-RQ-01], subsequent actions shall be planned, including the definition of the timeline for the remediation.

5.6.2.4 Output

- Documented decision on how to remediate the vulnerability
- Documented remediation plan, including the timeline

5.6.2.5 Assessment criteria

- Evidence of the documented decision
- Evidence of the remediation plan, including the timeline

5.6.3 [RMD-2] Remediation development

5.6.3.1 General

After the decision to remediate a particular vulnerability has been taken and planned, it is essential to perform the activities that produce the remediation. During these activities, the manufacturer could produce updates, documentation, or configuration changes, as appropriate, to address a vulnerability.

These activities can involve third parties, including suppliers and open-source projects, to coordinate the development or source existing remediation.

5.6.3.1.1 REVISED: Rationale and Guidance (NL:2004)

5.6.3.2 Input

- Decision on remediation of the vulnerability
- Remediation plan, including the timeline

5.6.3.3 Requirement

[RMD-2-RQ-01] The remediation shall be produced.

NOTE 1 The development of the remediation follows the internal processes defined by the manufacturer as per [Error! Reference source not found.](#), Clause 7.

NOTE 2 For additional guidance related to remediation development requirement, refer to [Error! Reference source not found.](#), 7.1.5. b).

NOTE 3 Existing remediation from third parties can be used to address the vulnerability.

NOTE 4 Remediation development can include any artefact that addresses the vulnerability. For example, updating user documentation.

[RMD-2-RQ-02] Security updates shall be provided separately from functional updates, where technically feasible.

NOTE 5 Technical feasibility: the degree to which the proposed system design and architecture can be implemented using available technology, within constraints such as cost, schedule, and performance.

NOTE 6 Technical feasibility, can also consider operational feasibility, where the goal is to ensure the solution can be effectively integrated, maintained, and supported.

5.6.3.4 Output

- Produced remediation and related documentation

5.6.3.5 Assessment criteria

- Evidence of a produced remediation and related documentation

5.6.4 [RMD-3] Remediation test

5.6.4.1 General

This subclause describes the activities to develop and perform appropriate tests to ensure that the risks associated with a vulnerability are mitigated without a negative impact on the product or users.

5.6.4.1.1 REVISED: Rationale and Guidance (NL:2004)

5.6.4.2 Input

- Remediation decision
- Produced remediation and related documentation

5.6.4.3 Requirement

[RMD-3-RQ-01] The remediation shall be tested to ensure the risks related to the vulnerability are mitigated and the impact on the product and the users is acceptable.

NOTE 1 For additional guidance on testing of remediation, refer to [Error! Reference source not found.](#), 7.6.

NOTE 2 For additional guidance related to the remediation test requirement, refer to [Error! Reference source not found.](#), 7.1.5 c).

NOTE 3 When remediation originates from third parties, the manufacturer will, to the extent reasonably practicable, verify the remediation at the product level and confirm functional performance; full underlying component verification is performed by the supplier.

5.6.4.4 Output

- Remediation test report
- Tested remediation

5.6.4.5 Assessment criteria

- Evidence of the remediation test report
- Tested remediation exists

5.7 [RLS] Release

5.7.1 General

The release phase includes requirements for deploying and sharing remediation, describing associated changes, and disseminating remediation information to relevant stakeholders.

5.7.1.1 REVISED: Rationale and Guidance (NL:2004)

5.7.2 [RLS-1] Security update release

5.7.2.1 General

This subclause addresses the activities of gathering all the artefacts to address vulnerabilities and disseminating security updates.

Any delay in applying security updates gives attackers time to exploit the product's vulnerabilities. Therefore, the timely distribution of security updates is essential. A secure update distribution mechanism ensures the integrity and authenticity of security updates. An automatic update distribution mechanism ensures that vulnerabilities are remediated without user interaction for the products that support automatic updates.

Such updates need to be provided in a secure manner, which might, for example, use digital signatures and/or secure download services.

Security updates are to be applied automatically or manually depending on the type of product, its technical implementation, its intended purpose, and its reasonably foreseeable use.

Providing security updates that do not change the product's other functionality reduces the risk of unintended or unwanted operational impacts in the user's environment. On the other hand, some remediations require significant changes that cannot be implemented without larger interventions into the product.

5.7.2.1.1 REVISED: Rationale and Guidance (NL:2004)

5.7.2.2 Input

— Tested security update or remediation as required per 5.6.4

5.7.2.3 Requirement

[RLS-1-RQ-01] Security updates shall be provided, unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge.

[RLS-1-RQ-02] Once a security update is provisioned, it shall be distributed in a timely manner.

NOTE 1 "Timely" in this context means that security updates that fix a critical vulnerability (i.e. risk for societal impact) are handled with appropriate priority by the manufacturer as established in 5.5.3.

NOTE 2 Expedite software updates to address critical security vulnerabilities.

NOTE 3 There are several distribution mechanisms, including automatic or manual. The product and infrastructure design need to provide an adequate distribution mechanism, taking into account the product's intended purpose and target users.

NOTE 4 For additional guidance for the distribution, refer to [Error! Reference source not found.](#), 7.7.

[RLS-1-RQ-03] Installation instructions shall be provided for security updates unless distribution is fully automated.

[RLS-1-RQ-04] The mechanisms to distribute security updates shall ensure their authenticity and integrity.

5.7.2.4 Output

- Distribution of security update
- Installation instructions resulting from [RLS-1-RQ-03]

5.7.2.5 Assessment criteria

- Evidence of security update distribution
- Evidence of implemented security update mechanisms for secure distribution of security updates.
- Evidence of the implementation of automatic security update distribution mechanism for products capable of being automatically updated.
- Evidence of installation instructions

5.7.3 [RLS-2] Release information

5.7.3.1 General

This phase describes a process for publishing information about resolved vulnerabilities and the distribution of corresponding security updates. It includes detailed guidance on communication, publication, and coordination with users and other stakeholders. Publications such as advisories or release notes provide clear, comprehensive documentation to help understand the nature of the vulnerabilities and manage associated risks effectively.

5.7.3.1.1 REVISED: Rationale and Guidance (NL:2004)

5.7.3.2 Input

- Tested security update as required per 5.6.4
- Policy on coordinating vulnerability disclosure (CVD)

5.7.3.3 Requirement

[RLS-2-RQ-01] Information of fixed vulnerabilities shall be published in accordance with the policy on coordinating vulnerability disclosure (CVD) as required by [PRE-2-RQ-01], and where appropriate, this information can be summarized or aggregated.

NOTE 1 For additional guidance on publishing vulnerability advisories, refer to [Error! Reference source not found.](#), Clause 7.

[RLS-2-RQ-02] The publication shall contain at least, but not limited to, the following information to enable the target audience to decide if the vulnerabilities are relevant and how to remediate them:

- description of the vulnerability;
- vulnerability identifier;
- information allowing the identification of the affected product;
- potential impact of the vulnerability;
- severity of the vulnerability;
- detailed information on how to remediate the vulnerability;
- release date and update date.

NOTE 2 For additional guidance on advisory elements, refer to [Error! Reference source not found.](#), 7.4.

[RLS-2-RQ-03] Information regarding fixed vulnerabilities shall be made available in a human-readable format.

[RLS-2-RQ-03-RE] Information regarding fixed vulnerabilities shall be made available in a widely recognized machine-readable format.

NOTE 3 Machine-readable format is specified in [Error! Reference source not found.](#)

[RLS-2-PM-01] To give sufficient time to distribute the security update, full publication according to *[RLS-2-RQ-02]* may be delayed if all the following conditions apply:

- An evaluation determines that the security risks of full publication outweigh the security benefits.
- Information about a vulnerability fixed by the security update is made available to users in such a way that an attacker could not use this information to exploit the vulnerability.
- Product users are informed about the date of public disclosure of all vulnerability information, as required per *[RLS-3-RQ-02]*.

[RLS-2-RC-01] Vulnerability information from *[RLS-2-RQ-01]* should be made publicly available on the EU Vulnerability Database (EUVD).

NOTE 4 If vulnerability information is disclosed through the CVE program, EUVD automatically adds it to its database.

5.7.3.3.1 Revised: Requirement

[RLS-2-RQ-01] Information of fixed vulnerabilities shall be published in accordance with the policy on coordinating vulnerability disclosure (CVD) as required by *[PRE-2-RQ-01]*, and where appropriate, this information can be summarized or aggregated.

NOTE For additional guidance on publishing vulnerability advisories, refer to [Error! Reference source not found.](#), Clause 7.

5.7.3.4 Output

- Publicly disclosed information on vulnerabilities addressed by the security update

- Rationale for delaying publication

5.7.3.5 Assessment criteria

- Evidence of published information on vulnerabilities addressed by the security update
- Evidence of published machine-readable information on vulnerabilities addressed by the security update, if applicable
- Evidence of published information on vulnerabilities addressed by the security update at EUVD, if applicable
- Evidence of information on publication delay, where permission [RLS-2-PM-01] was utilized

5.8 [PRA] Post-release

5.8.1 General

The post-release phase focuses on activities that occur after the remediation and release of a vulnerability. It includes requirements for monitoring released security updates, capturing lessons learned, and reflecting on the post-release process to inform and improve future development practices.

5.8.1.1 REVISED: Rationale and Guidance (NL:2004)

5.8.2 [PRA-1] Post-release actions

5.8.2.1 General

This phase is crucial for ensuring the ongoing quality and effectiveness of the remediation. The manufacturer has the discretion to apply this action in a way that enables continuous improvement of their product-related processes.

5.8.2.1.1 REVISED: Rationale and Guidance (NL:2004)

5.8.2.2 Input

- Tracked and prioritized list of vulnerabilities with their assessed risks
- Vulnerability remediation

5.8.2.3 Requirement

[PRA-1-RQ-01] Post-release actions shall be carried out, including:

- Case maintenance
- Monitoring of remediation

NOTE 1 Monitoring of remediation can be part of the overall 5.4.3.

NOTE 2 For additional guidance on post-release, refer to [Error! Reference source not found.](#), 7.1.7.

5.8.2.4 Output

- Documentation of post-release actions and related plan

5.8.2.5 Assessment criteria

- Evidence of post-release actions exists
- Evidence on the execution of the post-release actions as specified in [PRA-RQ-01]

Annex A

(informative)

(NEW ANNEX: HASR2-002 / HAS-3089) - RISKS COLLECTIONS AND MAPPING

NOTE: WORK IN PROGRESS - ANGELO STILL NEED TO FIGURE IT OUT HOW TO DEFINE THIS SECTION - ONCE READY WILL PRESENT TO THE GROUP

Notes on the objectives - Risks

[PRE-1] Policy on vulnerability handling (FR-1593 - Vulnerability handling policy)

- **[PRE-1-RQ-01] / [PRE-1-RC-02]-** *Wasting time during the resolution of the issues because of lack organization policies and R&R*

Annex B (informative)

Reccomendations

[PRE-1] Policy on vulnerability handling (FR-1593 - Vulnerability handling policy)

- **[PRE-1-RC-01]** *An organizational framework should be created to support the activities defined within this document.*

NOTE 1 For additional guidance on organizational framework, refer to [Error! Reference source not found.](#), 6.4.

- **[PRE-1-RC-02]** A vulnerability handling policy should include:
 - Statements concerning the creation of processes that are aligned with this document
 - A strategy to establish, document, and maintain relationships with **downstream stakeholders**(from: In *ISO/IEC TR 5895:2022(E)* mentioned as Dependent vendors are typically downstream of mitigating vendors), where known and appropriate
 - A strategy to establish, document, and maintain a list and relationship to complement the information as per 5.3.8 and 5.3.9 activities

Warning — ACTION ITEM FOR WG9: The vulnerability handling policy as at the moment is linked to the the section 8 MPCVD life cycle for each product - the invitation for the WG9 members is to reflect on this section and come out with concrete proposal on how to address the problem with : upstream and downstream stakeholders

NOTE 2 For additional guidance on roles and responsibilities in a multi-party configuration that includes definition of usual activities, refer to [Error! Reference source not found.](#), Clause 8.

Annex ZA (informative)

Relationship between this European Standard and the essential cybersecurity requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) aimed to be covered

This European Standard has been prepared under a Commission's standardization request C(2025)618 ('M/606') ¹⁾ to provide one voluntary means of conforming to the essential cybersecurity requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once this standard is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of this standard given in Table ZA.1 confers, within the limits of the scope of this standard, a presumption of conformity with the corresponding essential cybersecurity requirements of that Regulation, and associated EFTA regulations.

Where a definition in this standard differs from a definition of the same term set out in Regulation (EU) 2024/2847, the differences shall be indicated in this Annex Z. Where a reference from a clause of this standard to risk assessment is made, the risk assessment process needs to be in compliance with Regulation (EU) 2024/2847. For the purpose of using this standard in support of the requirements set out in Regulation (EU) 2024/2847, the definitions set out in the Regulation prevail.

Table ZA.1 — Correspondence between this European Standard and Annex I of the Cyber Resilience Act

Essential cybersecurity requirements of Regulation (EU) 2024/2847	Clause(s)/sub-clause(s) of this EN	Remarks/Notes
Annex I, Part 2, (1)	5.3.7, 5.3.8, 5.3.9, 5.4.3, 5.4.4, 5.4.5	
Annex I, Part 2, (2)	5.3.2, 5.3.4, 5.3.5, 5.4.6, 5.5.2, 5.5.3, 5.6.2, 5.6.3, 5.6.4, 5.7.2, 5.8.2	

¹⁾ COMMISSION IMPLEMENTING DECISION of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Essential cybersecurity requirements of Regulation (EU) 2024/2847	Clause(s)/sub-clause(s) of this EN	Remarks/Notes
Annex I, Part 2, (3)	5.3.10, 5.4.3, 5.4.7, 5.4.8, 5.8.2	
Annex I, Part 2, (4)	5.3.7, 5.7.3	
Annex I, Part 2, (5)	5.3.3	
Annex I, Part 2, (6)	5.3.6, 5.4.2	
Annex I, Part 2, (7)	5.7.2, 5.3.11, 5.5.3, 5.8.2	
Annex I, Part 2, (8)	5.3.11, 5.7.2, 5.7.3	

Warning — Presumption of conformity stays valid only as long as a reference to this European Standard is maintained in the list published in the Official Journal of the European Union. Users of this standard should consult frequently the latest list published in the Official Journal of the European Union.

Warning — Other Union legislation may be applicable to the products falling within the scope of this standard

Bibliography

- [1] prEN 40000-1-2, *Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience*
- [2] EN ISO/IEC 30111:2020, *Information technology - Security techniques - Vulnerability handling processes (ISO/IEC 30111:2019)*
- [3] EN ISO/IEC 29147:2020, *Information technology - Security techniques - Vulnerability disclosure (ISO/IEC 29147:2018)*
- [4] ISO/IEC TR 5895:2022, *Cybersecurity — Multi-party coordinated vulnerability disclosure and handling*
- [5] ISO/IEC/IEEE 29119-2:2021, *Software and systems engineering — Software testing — Part 2: Test processes*
- [6] ISO 31073:2022, *Risk management — Vocabulary*
- [7] ISO 28001:2007, *Security management systems for the supply chain — Best practices for implementing supply chain security, assessments and plans — Requirements and guidance*
- [8] ISO/IEC 29147:2018, *Information technology — Security techniques — Vulnerability disclosure*
- [9] EN 301 549 v3.2.1, *Accessibility requirements for ICT products and services*
- [10] prEN IEC 61360-7:2025, *Standard data element types with associated classification scheme - Part 7: Data dictionary of cross-domain concepts*
- [11] BSI TR-03183:v2.1.0 *Cyber Resilience Requirements for Manufacturers and Products - Part 2: Software Bill of Materials (SBOM)*
- [12] ISO/IEC 27036-3:2023, *Cybersecurity — Supplier relationships — Part 3: Guidelines for hardware, software, and services supply chain security*
- [13] ISO/IEC 5962:2021, *Information technology — SPDX® Specification V2.2.1*
- [14] ISO 8601-1:2019, *Date and time — Representations for information interchange — Part 1: Basic rules*
- [15] prEN 40000-1-2:2025, *Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience*
- [16] RFC 9116:2022, *A File Format to Aid in Security Vulnerability Disclosure*
- [17] ISO/IEC 20153:2025, *Information technology — OASIS Common Security Advisory Framework (CSAF) v2.0 Specification*